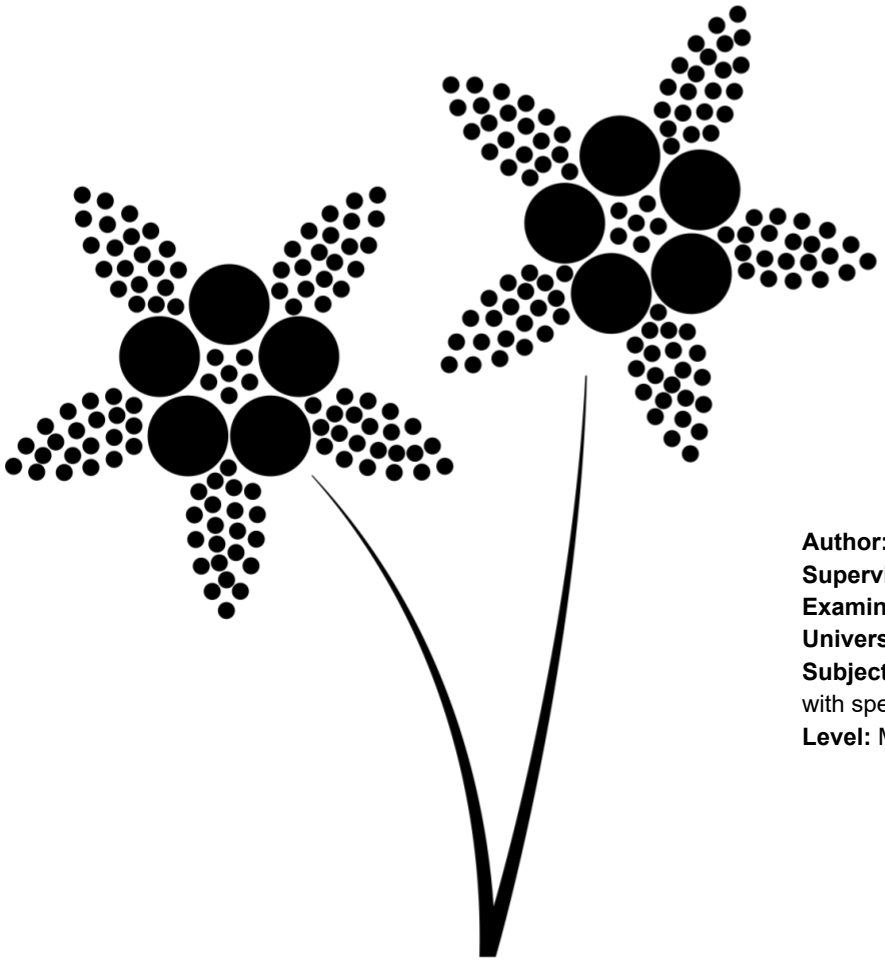
Linnæus University

A Decision-Support Framework for Cybersecurity-by-Design in Small and Medium-sized Enterprise Product Development

A Multiple-Case Study



Author: Kwabena Agyei Sasu-Boakye
Supervisor: Hemant Ghayvat
Examiner: Jimmy Johansson
University: Linnaeus University
Subject: 26VT - 5TS04E - Engineering with specialization in Innovation
Level: Master's

Linnæus University

Abstract

Small and medium-sized enterprises that build products with digital elements now face a new EU obligation. The EU Cyber Resilience Act makes cybersecurity a mandatory design requirement, yet most of these SMEs decide on security during product development with little structure and few resources. This thesis asks how those decisions are made and how they can be supported. It uses Design Science Research to study the problem and to build a response. The empirical work is an embedded multi-case study of three Swedish SMEs, with eight semi-structured interviews and onsite observation of the product development life cycle at the primary case. The findings show that cybersecurity decisions are mainly made at a small number of design moments, that the difficulty of interpreting regulatory text is the central friction, and organisational maturity, rather than company size, shaped practice the most. From these findings the thesis develops a decision-support framework that organises cybersecurity decisions across four product development phases, calibrates the depth of engagement to three maturity levels, maps each decision to the relevant Cyber Resilience Act articles, and gathers governance and human factors into an adoption-readiness check. The framework was assessed in a formative evaluation by five practitioners at the primary case against utility, clarity, relevance, and adoption, where it was rated most highly for making decisions consistent and defensible. The thesis contributes an empirical account of SME cybersecurity decision-making, a design-stage framework grounded in that account, and an integration of five research areas that have developed separately.

Keywords

cybersecurity-by-design; secure-by-design; decision-support framework; small and medium-sized enterprises; product development; EU Cyber Resilience Act; regulatory compliance; Design Science Research; cybersecurity maturity

I dedicate this to my late mother, Georgina Sasu-Boakye, whose love and forcefulness has been a blueprint I have drawn on all my life. I wish you were here to see this. This is for you.

Acknowledgments

I would like to thank God for the strength, health, and clear mind to see this work through to the end. I would also like to thank my supervisor Hemant Ghayvat and Peter Lerman, for the guidance and steady feedback that shaped this work. I am grateful to JEMAC Sweden AB for hosting the study, and to the teams at Dectron 2.0 AB and Sourceful Energy who gave their time to the interviews. And to my family and friends who stood by me through the long days and encouraged me when the work felt heavy, thank you. I am especially grateful to my brother, Yaw, who walked the road ahead of me so that I could follow it. You showed me how far it is possible to go, and you made sure I had the chance to try. I could not have done this without you all.

Linnæus University

Table of Contents

1 Introduction 7
1.1 Background and Problem Description 7
1.2 Aim and Purpose 8
1.3 Scope and Limitations 8

2 Literature Review 9
2.1 The Cybersecurity Challenge for Small and Medium Sized Enterprises 9
2.2 Secure-by-Design: From Principle to Practice 10
2.3 Cybersecurity Compliance: From Voluntary Frameworks to Mandatory Law 11
2.4 Decision-Support Systems for Cybersecurity: The Design Stage Gap 12
2.5 Human and Behavioural Dimensions of Cybersecurity Adoption 12
2.6 Synthesis: Research Gaps and the Case for an Integrative Framework 13

3 Methodology 14
3.1 Research Philosophy and Approach 14
3.2 Research Design 14
3.3 Data Collection 15
3.4 Case Descriptions 16
3.5 Data Analysis 17
3.6 Framework Design and Development 18
3.7 Evaluation Strategy 18
3.8 Assumptions, Quality and Ethical Considerations 19

4 Results 20
4.1 Thematic Analysis Findings 20
4.1.1 Cybersecurity Decision-Making in Practice 20
4.1.2 Regulation and Compliance in Practice 21
4.1.3 People, Resources and Organisation 23
4.2 Cross-Case Comparison 25
4.2.1 JEMAC Primary Case Observation (Pedaly Project) 26
4.3 The Framework 27
4.3.1 Structure 27
4.3.2 CRA Alignment 29

5 Discussion 31
5.1 Interpretation as the Central Friction 31
5.2 Maturity as the Determining Variable 32
5.3 Leadership and the Conditions for Adoption 33
5.4 Two Surfaces, One Framework 34
5.5 What the Framework Contributes Beyond Existing Frameworks 35
5.6 Evaluation of the Framework 35

6 Conclusion 38
6.1 Contributions of the Work 38
6.2 Practical Implications 38
6.3 Limitations 38
6.4 Directions for Future Research 39

Appendices

Appendix A — Data Collection Instruments
Appendix B — Coded Data
Appendix C — Framework Artefacts

1 Introduction

This chapter introduces the research and outlines the background, problem context, aim, and scope of the study.

1.1 Background and Problem Description

Small and medium-sized enterprises (SMEs) play a central role in driving innovation and economic development across Europe. Many of them are now building products that build in software, connectivity, and digital functionality (Benjamin et al., 2024). Even though this shift opens up new opportunities, it also introduces cybersecurity issues that can affect product safety, user trust, and the wider systems these products connect to (NIST, 2024).

Research consistently and continues to show that SMEs face challenges in managing these risks. They often don't have the financial resources, specialised knowledge, and formal security practices that most of the larger organisations rely on (ENISA, 2021). When cybersecurity incidents do occur, the consequences can be serious, ranging financial losses, reputational damage, safety concerns, and service disruptions (ENISA, 2021). These are not abstract or unreal risks; they affect real businesses and real users.

In the past, cybersecurity has been treated as a last-minute concern in product development rather than a foundational, right from the beginning, design principle. Security measures are often added on after the main design decisions have already been made. Prior research shows that this approach is very costly and most of the time not so effective. Introducing security requirements after initial design decisions substantially increases costs and reduces the effectiveness of the resulting measures (Boehm, 1981; Saltzer and Schroeder, 1975).

The European Union is now changing the rules. The Cyber Resilience Act (CRA), which entered into force in December 2024, moves cybersecurity from voluntary best practice to a mandatory product design requirement. The regulation places a lot of importance on secure-by-design and secure-by-default principles, and requires that manufacturers start to address cybersecurity risks throughout the entire product lifecycle (European Commission, 2024). This is not a minor policy update. Cybersecurity considerations will now directly shape early product development decisions, including the architectural design choices, the prioritisation of functionality, and risk management strategies that product developers of connected products make.

Despite this growing regulatory focus, SMEs frequently struggle to put cybersecurity requirements into practice within their development processes. Established frameworks such as the ISO/IEC 27001 are designed with larger organisations in mind. They concentrate more on governance and control but offer limited practical support for the decisions that product teams actually face and have to make during early development (Ashenden and Lawrence, 2016). As a result, cybersecurity decisions in SMEs are usually

made on an ad hoc basis or deferred entirely. This creates a widening gap between what regulations demand and what development teams actually do.

This gap points to a clear need for structured, accessible decision support that helps SMEs integrate cybersecurity early in the product development process. Such support must balance security requirements with innovation goals and real-world resource constraints. Addressing this issue matters not only for the SMEs themselves but also for building a broader societal trust in the digital products entering the European market.

1.2 Aim and Purpose

The aim of this thesis is to design and evaluate a decision-support framework that assists SMEs in integrating cybersecurity-by-design into their product development processes.

This is to support SMEs in making more informed cybersecurity related design decisions during the early stages of product development, where choices carry long-term consequences for product security, cost, and regulatory compliance. By drawing on principles from decision-support systems and cybersecurity-by-design, the study aims to help SMEs prioritise security requirements despite having limited resources while at the same time improving the consistency and transparency of security decision-making. The framework also seeks to support alignment with emerging EU regulatory requirements, with a main emphasis on those introduced by the CRA.

The study is guided by three research questions:

1. What characterises cybersecurity decision-making in SME product development?

2. How can a decision-support framework support SME alignment with the secure-by-design requirements of the EU Cyber Resilience Act?

3. What human and organisational factors should such a framework account for to support adoption in resource-constrained SMEs?

1.3 Scope and Limitations

This thesis has limits. The first one is that the study looks at cybersecurity through a decision-support and design lens. It does not cover how individual security measures are implemented in code or hardware, and it does not try to verify legal compliance with the CRA in a formal sense.

Also, the empirical work rests on three SME cases in an embedded multi-case design. One SME is the primary case, where the author combines participant-observation with interviews. The other two SMEs are comparison cases, studied through interviews only. This gives variation across product types and company settings, but it does not claim to represent every SME affected by the CRA.

2 Literature Review

The literature that bears on this thesis does not belong to a single field. It spans cybersecurity engineering, regulatory studies, organisational behaviour, design science, and decision theory.

2.1 The Cybersecurity Challenge for Small and Medium Sized Enterprises

Most cybersecurity research has treated the large enterprise as its default subject. The assumptions informing major frameworks and standards are more often than not grounded in how large organisations operate (Tetteh, 2024). When SMEs appear in this literature, they are typically treated as a smaller version of the same problem but this is not the case and there is evidence that suggest otherwise.

Rombaldo Junior, Becker and Johnson (2025) conducted a comprehensive systematic review of SME cybersecurity literature, covering 132 studies. Their central argument is that limited cybersecurity literacy is the root cause of SME failure, not just a symptom. An organisation that does not understand its threat landscape cannot allocate its limited resources well to address them. Awareness campaigns alone are not enough unless the literacy gap is addressed where decisions are actually made. The authors also note that most SME cybersecurity research has stagnated, repeating established findings without adding new insight.

That said, the root cause debate is far from settled. Awan and Alam (2025), mapping 73 articles, treat financial and resource constraints as the main barrier. Ludin, Mohd and Fauzi (2025), reviewing 57 studies on security training adoption in SMEs, locate the problem in organisational culture, emphasising that lack of management support and cultural resistance matter more than the availability of training programmes. Rawindaran, Jayal, Prakash and Hewage (2023) add a fourth explanation from fieldwork with 34 Welsh SMEs. They discovered that government schemes like Cyber Essentials are frequently unknown or poorly fitted to SME contexts. The failure is not a lack of policy intent but a gap in outreach and translation.

These four explanations are not in direct conflict. They describe the same problem from different angles, and an effective framework has to account for where an SME actually sits rather than assume a single starting point.

In the same vein, there is broad agreement that generic enterprise frameworks do not transfer well to SMEs. Metin, Özhan and Wynn (2024) identify the specific reason: standards like ISO 27001 and the NIST Cybersecurity Framework (CSF) require skilled security experts to interpret, the very resource, most if not all, SMEs lack. Two papers attempt to propose SME-specific alternatives. Pawar and Palivela (2022) propose a tiered prioritisation framework calibrated to SME constraints, while El-Hajj and Mirza (2024)

develop a risk assessment tool combining elements of NIST CSF and ISO 27001. But neither addresses the moment when a product team must decide what security architecture to build before writing code.

2.2 Secure-by-Design: From Principle to Practice

The principle that security should be designed into products right from the onset rather than added later has a long history. Saltzer and Schroeder (1975) articulated it in the 1970s, and every major cybersecurity standard since has endorsed it in some way. Yet the gap between endorsement and implementation has always been wide.

Ruohonen (2025) traces the adoption of secure-by-default across contexts from IoT manufacturing and finds a consistent pattern that endorsement is universal, but misapplication is close to universal too. Developers accept the principle but struggle to put it into practice, often because no one has specified what it actually requires in a given product context. This is a knowledge and process problem, not a motivation problem.

Del-Real, De Busser and van den Berg (2024) make the definitional gap clear. They reviewed 86 definitions of Security by Design across 46 studies and found that the term lacks the shared grounding and cross-disciplinary agreement that Privacy by Design built up over a similar period. There is no agreed scope or no shared way to put it into practice, and more worrying, no clear test for telling secure-by-design development apart from ordinary development that happens to include some security work. Any framework that claims to put cybersecurity-by-design into practice has to start by setting out what it actually means.

Building security into the software development lifecycle has its own research stream, but it carries a few persistent problems. Kudriavtseva and Gadyatskaya (2023) review 28 secure software development lifecycle (SDLC) methods and find that most of them treat security as a purely technical issue, with organisational and behavioural factors left out. There is very thin evidence of effectiveness. Eian, Ka Yong, Hasmaddi and Fatima-tuz-Zahra (2020) map security modules to SDLC phases but show that adoption fails when organisational support is missing. ValdesRodriguez, Hochstetter-Diez, Díaz-Arancibia and Cadena-Martínez (2023) note that no model yet ties security requirements to the iterative release cycles of agile development, which is how most SMEs actually work. Granata and Rak (2024) find that automated threat modelling tools, the current frontier for design-stage security, still treat threats in isolation and do not support continuous feedback.

Akinsanya (2025) provides the strongest empirical evidence for what is possible when secure-by-design is implemented well. A hybrid model combining threat modelling, automated compliance checks, and governance structures produced a 54% reduction in critical vulnerabilities and 39% lower incident response costs. However, all three case studies involved large organisations with dedicated security teams, established pipelines,

and professional staff. These are exactly the conditions that SMEs do not have, and the evidence cannot simply be assumed to transfer.

2.3 Cybersecurity Compliance: From Voluntary Frameworks to Mandatory Law

For much of the past two decades, cybersecurity compliance for product developers meant voluntary adoption of frameworks designed by standards bodies and government agencies such as NIST CSF, ISO 27001, and OWASP SAMM. These were designed with large enterprises in mind, and the literature consistently shows that without external pressure, most SMEs do not engage with them (Odujinrin, 2023; Rawindaran et al., 2023; Rombaldo Junior et al., 2025).

The EU Cyber Resilience Act, which entered into force in December 2024, changes this fundamentally (Risto et al., 2025; European Commission, 2024). Before the CRA, security was a voluntary concern for manufacturers, pursued where it offered competitive advantage and removed in situations where it created huge cost implications. The CRA changes this with secure-by-design, vulnerability management, software bill of materials (SBOM) production, incident reporting, and post-market monitoring which are now legal obligations for any manufacturer placing a product with digital elements on the EU market (European Commission, 2024).

Teichmann (2026) provides the most thorough legal analysis of the CRA. The regulation covers all products with digital elements and introduces a risk based classification system with escalating assessment requirements. The same obligations apply regardless of firm size (European Commission, 2024). Ruohonen and Timmers (2025) focus on the most novel operational requirement which expects manufacturers to report actively exploited vulnerabilities to authorities within 24 hours starting from September 2026. This will create practical difficulties for organisations without existing security operations.

The readiness picture is not encouraging. Risto, Sethi and Katara (2025) surveyed industrial equipment manufacturers, organisations with considerably more resources than typical SMEs, and found unresolved hurdles in secure SDLC implementation, vulnerability notification, and cybersecurity expertise. Small Business Standards (SBS, 2023) warns that CRA compliance costs are disproportionately burdensome for SMEs, and that without proportionality measures the regulation risks excluding smaller firms from the EU market.

There is, however, a dimension of the CRA that existing literature largely ignores. The readiness surveys ask whether SMEs can meet CRA requirements. They do not ask how CRA requirements change the decisions SMEs make during product development, or what support teams need to make those decisions well.

2.4 Decision-Support Systems for Cybersecurity: The Design Stage Gap

Decision-support systems (DSS) are information systems that help people make structured and semi-structured decisions by providing data, models, and analytical tools (Power, 2008). François, Arduin and Merad (2023) give the most comprehensive classification of cybersecurity DSS and confirm that most existing tools target operational decisions such as intrusion detection, vulnerability triage, and incident response. NIST (2024) makes a similar point and notes that design-stage security guidance is the least developed area. Design choices, the point where a team decides what security architecture to build, sit in the least explored corner of the DSS taxonomy. No published DSS, to the best of the author's knowledge, addresses them.

Shimizu and Hashimoto (2025) reach an 18-fold improvement in efficiency by chaining three signals: the Known Exploited Vulnerabilities (KEV) catalogue, the Exploit Prediction Scoring System (EPSS), and the Common Vulnerability Scoring System (CVSS). The result is strong, but it applies to post-release triage, not design-stage choices. Jiang et al. (2025) show the same pattern across 417 publications on MITRE ATT&CK. The framework is foundational for threat intelligence, but it operates after deployment. Awan et al. (2026) come closest to a design-stage DSS for SMEs with a generative AI framework for development planning, but their tool targets process management rather than the specific trade-off decisions at the design stage. Sukumar, Mahdiraji and Jafari-Sadeghi (2023) present a multilevel decision-making approach for cyber risk assessment in small e-tailing SMEs, but the tool scores risk on existing products rather than guiding the architectural choices made before code is written.

What unites these contributions is an orientation toward problems where the product is already built and the threat is already known. The design stage, where security decisions carry the longest-lasting consequences and the lowest cost of implementation (Fagan et al., 2024), has drawn almost no DSS research.

2.5 Human and Behavioural Dimensions of Cybersecurity Adoption

The literature on security failures consistently identifies human behaviour as a primary driver, yet the frameworks designed to improve security consistently treat the human as a secondary concern.

Khadka and Ullah (2025) bring together 41 studies across psychology, sociology, and cybersecurity to argue that cognitive fatigue, decision making biases, and trust dynamics are primary causes of security failures. Their argument for decision-support systems rests on cognitive load theory, which suggests that security decisions are made under time pressure, incomplete information, and competing priorities. Frameworks that increase complexity through lengthy checklists or specialist vocabulary produce worse decisions. A

well-designed decision-support system reduces cognitive load by structuring the decision environment.

Mihelic, Hovelja and Vrhovec (2025) provide the most detailed empirical analysis of how developers adopt secure practices, surveying 463 practitioners. Their central finding is that adoption works differently before and after initial uptake. Before adoption, social norms and risk awareness drive behaviour. After adoption, ease of use and attitude are what sustains it. No existing framework accounts for this distinction, which means a single framework cannot serve both populations well without adjusting to where an SME sits in the adoption journey.

Odujinrin (2023), studying five US small business IT leaders, finds that top management involvement is the single most important enabler of security compliance. Without leadership actively modelling threat awareness, technical measures and training do not produce lasting behaviour change. This resonates with Ludin et al.'s (2025) findings on management culture and Kudriavtseva and Gadyatskaya's (2023) observation that secure SDLC methodologies neglect governance. The pattern across methods and contexts is consistent. Human and organisational factors are not secondary but rather central to cybersecurity effectiveness.

2.6 Synthesis: Research Gaps and the Case for an Integrative Framework

First, no decision-support tool for cybersecurity has been empirically tested at the design stage of product development (François et al., 2023). Operational DSS has advanced, but the design stage remains unsupported. Second, the root cause of SME cybersecurity failure remains contested among four competing accounts, and no study has tested them against one another. Frameworks therefore pick one explanation implicitly and design accordingly. Third, the CRA's impact on product development decision making has not been studied. Existing work focuses on compliance readiness, not on how the regulation changes the decisions teams actually make. Fourth, there is no evidence that secure-by-design produces better outcomes in SME contexts. The strongest evidence (Akinsanya, 2025) comes from large enterprises whose conditions do not hold in SMEs. Fifth, human and behavioural factors are absent from every existing secure-by-design framework, despite strong evidence that they determine whether practitioners change their behaviour (Khadka and Ullah, 2025; Mihelic et al., 2025).

These five gaps converge on a sixth: the literature reviewed in this study did not identify a framework that integrates decision-support theory, secure-by-design, human factors, SME resource constraints, and CRA compliance into a single coherent model. The gap exists because it sits at the boundary of five disciplines that have developed independently, and none has sufficient scope to prioritise work at their shared edge. What the integration requires is a methodology that can draw from all five literature and produce a framework

that is both theoretically grounded and practically usable. This is the contribution Design Science Research makes possible, and it is the contribution this thesis pursues.

3 Methodology

This chapter describes how the research was conducted. It covers the research philosophy, methodology, data collection and analysis, framework design and evaluation, and the assumptions, quality criteria, and limitations that apply.

3.1 Research Philosophy and Approach

The central question for this research is what a useful decision-support framework for SME product teams looks like under the CRA. That question cannot be answered by measuring variables or running statistical tests. It requires understanding what practitioners actually know, what they need, and what gets in the way of acting on it. The study therefore adopts a qualitative approach, aiming for rich, situated insight rather than statistically representative findings.

3.2 Research Design

The study uses Design Science Research (DSR) as its methodology, following the process model of Peffers, Tuunanen, Rothenberger and Chatterjee (2007), shown in Figure 1. DSR is a good fit because the goal is not just to describe a problem but to build something that addresses it. In this case, that something is a decision-support framework for SME product teams. DSR combines theoretical grounding with practicality, and its outputs are evaluated against both rigour and relevance (Hevner, March, Park and Ram, 2004).

The empirical work is structured as an embedded multi-case design in the sense of Yin (2018). JEMAC Sweden AB serves as the primary case, with Dectron 2.0 AB and Sourceful Energy as comparison cases. The primary case carries both semi-structured interviews and onsite observation of the product development life cycle, while the comparison cases carry interviews only.

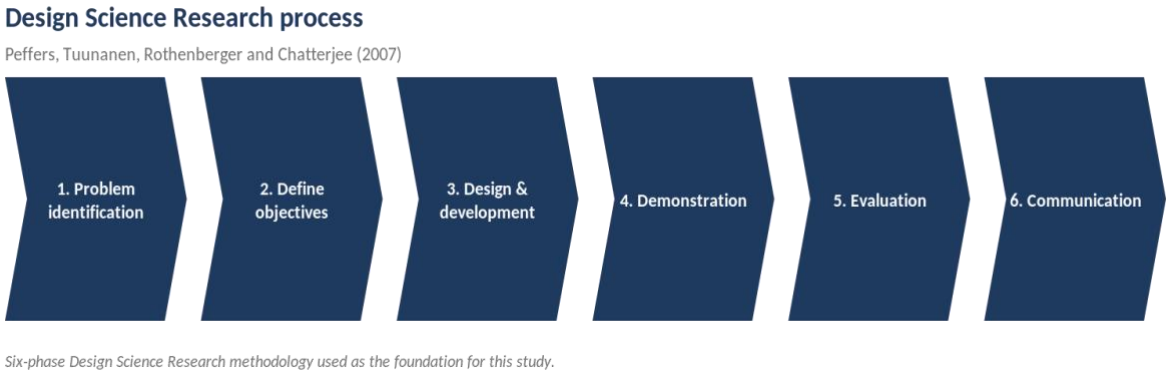


Figure 1 Design Science Research process model (Peffers et al., 2007), the methodological backbone for this thesis.

The research is structured around three phases adapted from Peffers et al. (2007). The first phase is problem identification and objective definition, carried out through a purposive literature review and a structured regulatory analysis of the CRA. The second phase is framework design and development, informed by both theoretical constructs and empirical findings from the case study, which combines semi-structured interviews across the three cases with onsite observation of the product development life cycle at the primary case. The third phase is structured practitioner evaluation using predefined criteria to assess the framework's utility, clarity, relevance, and adoption. The iterative nature of this cycle means the framework can be refined based on real feedback, which matters in a study where practical application is as important as the theoretical contribution.



Figure 2 The three phases of this thesis mapped onto the DSR cycle.

3.3 Data Collection

Data collection has four strands that inform the framework's design. The first is a purposive literature review (i.e., a non-exhaustive review in which papers are selected for their relevance to the five thematic areas rather than through systematic database screening) covering 39 papers across the five thematic areas discussed in Chapter 2. Papers were identified through systematic searches of Google Scholar, Scopus, and IEEE Xplore. To be included, a paper had to be peer reviewed and address at least one of the five thematic areas.

The second strand is a structured regulatory analysis of the Cyber Resilience Act, which was conducted alongside the literature review. The analysis covers an article-by-article reading of the regulation with plain-language summaries and where there was ambiguity, this was flagged. Finally, a mapping of each of the framework's twenty-five decisions to a specific CRA article. These steps produce the source material for the CRA at a Glance artefact (Appendix C3) and for the article-level citations carried through the framework.

The third strand is semi-structured interviews with key stakeholders from three SME case companies. Each company is selected on three criteria. It must qualify as an SME under the EU definition (European Commission, 2003), meaning fewer than 250 employees. It must be actively developing a product that involves digital or connected components where cybersecurity is directly relevant. And it must have at least one identifiable stage where cybersecurity decisions are currently being made or avoided. Interview participants include product managers, engineers, and technical leads involved in product development and decision-making. Interviews were conducted online or in person, recorded with consent, and lasted between 30 and 45 minutes. An interview guide is prepared in advance covering current cybersecurity practices, key decision points, constraints, and what kinds of decision support participants would find useful (Appendix A1; participant information sheet A2; consent form A3).

An embedded multi-case design is used. Three companies allow for cross-case comparison, which helps distinguish patterns that hold across contexts from those that are specific to one organisation. JEMAC is treated as the primary case because extended access was granted and this enabled onsite observation of the product development life cycle in addition to interviews. Dectron and Sourceful serve as comparison cases through interviews alone. The number of cases is kept small enough to allow for the rich, situated insight that DSR requires (Peffers et al., 2007). The three cases were selected to represent variation in product type, company size, and the nature of the digital elements involved, while all falling within the scope of the CRA.

The fourth strand is participant-observation of the product development life cycle at the primary case. The researcher held the role of quality engineer during the observation period and was involved in the cybersecurity workstream of the observed project. The observation is therefore conducted from inside the work, with the reflexivity safeguards described in Section 3.8.

There is a fifth source of data. The practitioner evaluation questionnaire also produces primary data. It tests the finished framework rather than informing its design. Its instrument and procedure are set out under Evaluation Strategy (Section 3.7), and its results are reported in Section 5.6.

3.4 Case Descriptions

This study draws on three SME case companies, all based in Sweden.

The first case company is JEMAC Sweden AB, a small technology firm based in Kalmar. JEMAC was founded in 2013 and currently employs 15 to 20 people. Its core business spans product development, production, and technical consulting, with a particular focus on Internet of Things (IoT) solutions. The company designs and builds connected products that integrate hardware, embedded software and cloud services. Within this study, JEMAC serves as the primary case. The researcher's quality-engineer role at JEMAC during the observation period provides extended access, which makes it possible to combine semi-structured interviews with participant-observation of the product development life cycle. The observed product cycle is the Pedaly Bike Dock Parking project, a connected bicycle-parking system with a master-and-slave node architecture, in pilot stage by the first quarter of 2026.

The second case company is Dectron 2.0 AB, an electronics development and manufacturing firm based in Färjestaden. Founded in 1989, Dectron has over 30 years of experience in electronic product development, Printed Circuit Board (PCB) manufacturing, and Electromagnetic Compatibility (EMC) testing. The company offers services ranging from electronics design and component selection through to production and compliance testing in a SWEDAC-accredited EMC laboratory. Cybersecurity is relevant here because the electronic products Dectron develops increasingly incorporate digital and connected components.

The third case company is Sourceful Energy, a software startup based in Kalmar with approximately 10 employees. Sourceful develops a Virtual Power Plant platform that connects distributed energy resources such as solar panels, batteries, and electric vehicle chargers. Its key product is the Energy Gateway, an IoT device that integrates these resources into the electricity grid through real-time coordination and optimisation. Cybersecurity is central to this product because it involves connected hardware, cloud-based control systems, and the management of energy infrastructure.

3.5 Data Analysis

Interview transcripts are analysed using thematic analysis following Braun and Clarke (2006). The work runs in two passes. In the first pass, codes are drawn from the data itself. The codes are grouped into themes that speak to the research questions, and each theme is checked back against the full dataset more than once.

In the second pass, the themes are mapped against theoretical ideas from the literature. A third step then compares themes across the three cases to see which patterns hold and where they break apart. Field notes from the JEMAC observation are coded against the same codebook as the interviews, but the source of each entry is kept separate in the record. Where an interview claim and an observation note land on the same code, the agreement strengthens the finding. Where they pull in different directions, the disagreement is itself treated as a finding.

This mix of cross-case comparison and source triangulation makes it possible to separate findings that hold across companies and across sources from those that belong to one company or one source only. The combined approach grounds the framework in both theory and practice. The same logic applies to the literature: contributions and gaps across the 39 papers are grouped by theme, and those themes feed back into the framework's design.

3.6 Framework Design and Development

The framework was built in three iterations, drawing on the literature review and the empirical data.

In the first iteration, the draft was put together from pieces already in the literature: established cybersecurity-by-design principles, decision-support system design patterns, and CRA compliance requirements. This first version set out the core structure, the components, and the context in which the framework was meant to be used.

In the second iteration, findings from the case studies were used to stress-test and refine that draft. Decision points, constraints, and support needs that came out of the interviews either backed up the theory or pushed against it. The result was a revised version of the framework.

In the third iteration, feedback from the practitioner evaluation informed a final round of revision. The version of the framework submitted with the thesis reflects the refinements this feedback made feasible within the project scope. The larger additions it surfaced are carried into future work.

The framework aims to do three things: identify the key cybersecurity decision points across the product development lifecycle, give guidance on how to prioritise security requirements under time and resource pressure, and map these elements onto what the CRA expects. It is conceptual. It is not a technical tool, but a structured guide for decision-making.

3.7 Evaluation Strategy

The framework was evaluated against three dimensions drawn from DSR evaluation practice (Hevner et al., 2004): utility, clarity, and relevance. Adoption was assessed alongside them as a practical condition on the three. Feedback was collected through a structured practitioner questionnaire.

The evaluation was carried out at the primary case. Five JEMAC practitioners spanning management and engineering roles reviewed the framework and its artefacts and completed the questionnaire, rating each statement from 1 to 10 across the evaluation dimensions and adding written comments.

Practitioner responses were coded against the evaluation dimensions and used to identify specific areas for refinement. The results are reported in Section 5.6.

3.8 Assumptions, Quality and Ethical Considerations

This research rests on three assumptions. The first is that the CRA remains substantively unchanged through the 2027 compliance period. The second is that participants' self-reported practices and maturity self-placement reflect how their teams actually work. The third is that the embedded sample, comprising interviews across three cases and onsite observation at the primary case, supports analytical generalisation rather than statistical generalisation.

Quality is assessed against the four criteria proposed by Lincoln and Guba (1985): credibility, transferability, dependability, and confirmability.

Three safeguards were applied alongside the audit trail. Weekly supervisor meetings throughout the fieldwork acted as a peer-debriefing channel. Coding choices, observation entries, and emerging themes were discussed with the supervisor before they were locked into the analysis. A source-traceability review was carried out before submission, mapping every claim in Chapter 4 to its underlying transcript segment or observation entry, so that no claim sits in the thesis without a record behind it. These safeguards do not remove the researcher's involvement in the JEMAC work, but they make the involvement visible and checkable.

For ethical considerations, informed consent is obtained from all participants. Identities are anonymised. Recordings and transcripts are stored securely. No sensitive personal data beyond professional experience is collected.

4 Results

4.1 Thematic Analysis Findings

Eight semi-structured interviews were conducted across three Swedish SMEs: JEMAC (5 participants), Dectron (2 participants), and Sourceful Energy (1 participant). The interviews were then transcribed, cleaned, and coded using thematic analysis following Braun and Clarke (2006). The coding produced 178 segments (148 from interviews, 30 from the observation). The interview data was coded under 50 codes within 15 themes. The data gotten from the observation was recorded in the same codebook, which in full makes up to 65 codes across 28 themes (Appendix B1 - codebook; Appendix B2 -observation log).

4.1.1 Cybersecurity Decision-Making in Practice

Timing of cybersecurity integration. All three companies agreed that cybersecurity should be considered from the very start of product development. At JEMAC, an engineer put it as a rule: *"the choice of architecture, the customer's requirements, and cybersecurity, those three have to come together."* At Sourceful, Sourceful leadership compared it to user interface design: *"one of those things, like user interface, that you need to have in mind all the time."* At Dectron, an engineer said they *"try to think of it as early as possible"* but acknowledged that they have limited experience with connected products.

This matters because the three companies are at very different stages of maturity. Even at Dectron, where most products are not connected to the internet, both participants recognised that cybersecurity cannot be added later. The problem was this was not translated in their daily practice.

At JEMAC, a manager illustrated this gap with the Wi-Fi dongle, which is the company's most talked about project. *"At the beginning, we did not have the safeguards to secure our data, encryption and so on, for our Wi-Fi dongle. But after a while, we started doing something in this area and we changed the whole approach."* Cybersecurity was added in mid-project rather than designed in. He was direct about where JEMAC stands today: *"Right now I would say we start more in the middle of the project. But starting from the beginning would be good."*

Decision mechanisms. The decisions that came up a lot were about choosing platforms and components, evaluating suppliers, and relying on personal experience. At JEMAC, choosing the right hardware platform was the single most impactful cybersecurity decision. An engineer gave a concrete example: *"We have this product, the Pedaly bike stand, and that has been developed on a platform that cannot conform to cybersecurity due to the lack of a hardware-accelerated crypto engine. So we have to do some workaround, make sure that it is physically locked, or that you cannot access it."* The wrong platform choice forced the team into physical workarounds instead of proper digital controls.

At Dectron, a manager linked component selection to cybersecurity capability, noting that addressing cybersecurity "may involve selection of components in some ways for the hardware." None of the three companies really used formal decision-support tools or frameworks for cybersecurity. At JEMAC, decisions relied on "common sense and common security." At Sourceful, the team relied on long professional experience. At Dectron, an engineer could not name any tools or guidelines at all. A manager at JEMAC pointed to supplier capability as critical: "it has been essential to understand if they can help us solve the problem, or if we have to do it by ourselves." JEMAC also brought in an external consultant from Nemko for their first project.

Integration into development workflow. At JEMAC, participants described cybersecurity as something that should be *"integrated in the design process in a natural way"* rather than sitting beside it as a separate activity. A manager wanted cybersecurity tied to project milestones, with checkpoints at each phase. An engineer gave a concrete example: introducing a logging module for security events into the Wi-Fi dongle project. At Dectron, the development process is entirely customer-driven. Cybersecurity enters the process only if the customer asks for it or if the product needs connectivity.

Preferred framework format. Here, there was a clear split between management and technical roles. Managers wanted checklists. JEMAC leadership said their ideal system would let them "shove *in all the information"* and get back a list of *"where we comply and where we do not comply."* They were specific about what they wanted: *"From where I sit, it would be just a list. Okay or not okay. And then someone telling me, you need to do this, and if you do not do that, here are the risks."* A manager at Dectron also wanted *"a way of simplifying this work"* through checklists.

Technical staff wanted something more dynamic. An engineer at JEMAC envisioned "*a collection of vector embeddings in a Qdrant database that I can query with my RAG*." Sourceful leadership wanted "*an AI that is constantly running and looking out*" and monitoring code repositories for compromised packages. Sourceful leadership described an agent that checks Git repositories against known vulnerabilities and sounds the alarm automatically. Sourceful leadership also cited the OWASP Top 10 as a model: "*a really concrete checklist*" of priority threats.

4.1.2 Regulation and Compliance in Practice

Regulatory awareness. CRA awareness was low across all eight participants. None had studied the regulation into detail or knew exactly what it demanded from them. At JEMAC, leadership described their knowledge as *"very limited"* and said he relied on the quality engineer. An engineer said he was *"not super familiar with it."* A manager said he had *"just a brief understanding"* and relied on those responsible. At Sourceful, Sourceful leadership knew more about NIS2 than the CRA and was unsure of the difference between them. At Dectron, an engineer said *"I know it is a thing, but I have not really had time to get into the details."* A manager was aware of the CRA but had not studied its requirements.

The only other regulation Dectron had engaged with was GDPR. The gap between the CRA's timeline and what practitioners actually know about it was one of the most striking findings in the data.

Regulatory impact on practice. At JEMAC, it was the Radio Equipment Directive (RED) that triggered cybersecurity engagement, not the CRA. The new cybersecurity requirements in the RED took effect in mid-2024 and forced the company to act. An engineer tied it directly to market access: *"from my understanding, we cannot have the CE marking unless we conform to the standards."* At Dectron, a manager expected the CRA to have an impact but compared it to earlier regulatory changes: *"There is always some initial struggle before such things are normalised in the development work. It is the same with all kinds of these regulations, like RoHS and REACH."* At Sourceful, NIS2 was the more relevant regulation. Sourceful leadership had started building an internal tool for incident reporting and onboarding processes in preparation.

Strategic response to regulation. At JEMAC, leadership's journey from scepticism to strategic commitment was one of the clearest stories in the data. Leadership described their first reaction: *"to be completely honest, in the beginning I thought this was, not rubbish, but a lot of work. I did not really understand how we could make money out of this."* Six to nine months later, their view had changed completely: *"looking at where we are now, it is becoming a competitive advantage. We use it when we go to customers."* Leadership reflected on the early uncertainty: *"I was thinking, was this the right decision, or should we just try to hide? Because the customers were not asking for it, they were not even knowing about it. But looking back, I think we made the right decision."* This shift from reluctant compliance to proactive market positioning was unique to JEMAC. Neither Dectron nor Sourceful described cybersecurity in competitive terms.

Compliance challenges. Interpreting standards was the most frequently cited difficulty. At JEMAC, an engineer said the biggest challenge is *"how you interpret and apply the standards to the products."* Leadership pointed to *"grey zones"* and *"lack of information"* as the core problem. A manager added a supplier dimension: not knowing whether component suppliers could support compliance, and the cost of choosing wrong and having to *"completely change the architecture."* At Dectron, an engineer described a different problem: *"things are moving quite fast. What was recommended last week is not necessarily the go-to thing to do today."* At Sourceful, documentation burden was the main concern. Sourceful leadership said *"paperwork is probably not one of those things that a startup is super happy about."*

Another challenge was customer awareness. At JEMAC, customers were not yet asking about cybersecurity compliance. JEMAC leadership noted that customers "cannot really translate these NIS2 or CRA directives into requirements on our products." At Dectron, the same dynamic plays out differently. The development process is entirely customer-driven, so without customer demand or regulatory force, cybersecurity will not enter Dectron's process. JEMAC leadership also anticipated what comes next: when large customers like

Telenor and Eon fully understand the CRA, they will push requirements down through their supply chains. “When they come after us, I just realise that we need to be prepared,” he said.

A third challenge was the unknown-unknowns problem. An engineer at Dectron put it simply: *“maybe you do not know what you do not know. You have to research, to ensure you do not miss anything.”* This kind of uncertainty is exactly what structured guidance is meant to address.

4.1.3 People, Resources and Organisation

Resource constraints. All three companies are small teams where people wear multiple hats. Dectron has about 20 employees, as a manager confirmed in the interview. Sourceful has approximately 10 employees and JEMAC has 15 to 20, both figures based on internal knowledge from working relationships during the case study. None has a dedicated cybersecurity person. At Sourceful, Sourceful leadership said *“we of course do not have one person who can sit and have this as their daytime job.”* At Dectron, an engineer studied computer science but had no electronics background. He learned hardware development on the job after a colleague left and now handles both hardware and firmware alone. At JEMAC, the company recently hired a quality engineer to handle cybersecurity alongside other compliance work.

Competing priorities. Time pressure was the dominant competing factor at JEMAC and Sourceful. At JEMAC, leadership said they would prioritise time to market over complete cybersecurity if a customer deadline demanded it: *“if we were not ready fast enough with all the aspects of cybersecurity, I would say, okay, let us launch the product. Then I would say, let us try to find a way to implement this via a firmware update later on.”* At Sourceful, Sourceful leadership described a pace where *“some of our products should not take more than a day from starting to delivery.”* Cost was not raised as a primary barrier by any participant. JEMAC leadership said he would *“weigh cybersecurity higher than cost, even if I cannot charge the customer.”* At Dectron, a manager said cybersecurity *“is a part of the product that needs to be addressed. It is not something you can avoid.”* Competing priorities were less visible at Dectron because their products are not yet connected enough to force trade-offs.

User experience versus security came up at Sourceful as a recurring tension. Sourceful leadership described situations where users ask *“why can’t you just get this link without having to log in?”* and the team has to hold the line on authentication.

Organisational learning. All three companies described building cybersecurity knowledge gradually. At JEMAC, leadership moved from scepticism to strategic commitment over six to nine months. A manager said the company had *“established guidelines for our internal use, but also for our customers to follow”* in the past six months. Leadership stressed that the learning was ongoing: *“We are learning as a team. There needs to be more people in the organisation who understand this.”* At Dectron, a manager

compared the learning curve to past regulatory changes like RoHS and REACH. He expected the same pattern: initial struggle, then normalisation. He also made the case for security thinking beyond connected products: *"to make them stable and not vulnerable to attacks like that."* At Sourceful, Sourceful leadership's background in network security gave the company a head start, but was realistic about what security can achieve: *"you cannot write secure code. There is no secure system."*

Security practices. The three companies differed in what they actually do. Sourceful had the most developed practices. Sourceful leadership described layered access controls where not everyone has access to all systems. Leadership paid particular attention to high-profile roles: *"should they have access to all the back-end systems? Is that really necessary?"* The company uses isolated development environments, especially important now that AI tools can leak development keys. Sourceful leadership was also building an internal tool for incident reporting, onboarding, and security training. Leadership shared a concrete example: a sophisticated phishing attack that targeted leadership through a fake podcast invitation. The attacker sent a link to a recording tool that turned out to be a Trojan horse. The layered access approach meant the damage would have been contained even if leadership had installed it.

At Dectron, security practices were more limited. An engineer described making devices read-only until you have physical access as a substitute for digital controls. A manager advocated building *"rugged solutions that can withstand such attacks"* even for products where cybersecurity is not an obvious concern. At JEMAC, practices were process-oriented: milestone checklists, documentation systems, and integration with the quality management process.

Organisational enablers. Leadership involvement was the single most important enabler. At JEMAC, leadership's personal decision to invest in cybersecurity drove the entire company's shift. Leadership made that decision even when customers were not asking for it and when the cost could not be passed on. Leadership hired a quality engineer, brought in external consultants, and started using cybersecurity compliance as a sales argument. At Sourceful, Sourceful leadership's background in network security and web security shaped the company from the start. Security was part of the culture, not something bolted on. At Dectron, leadership acknowledged the importance of cybersecurity but had not yet acted on it. This fits with the company's position at the threshold of connected product development.

Risk perception. This theme was most pronounced at Dectron. Both participants described their products as low-risk because they are mostly unconnected. A manager said *"it is, I would say, a small risk."* When asked directly whether they had made any cybersecurity decisions, he said *"not really."* Cybersecurity is theoretically understood but practically absent. The contrast with JEMAC, where the RED Directive forced action, and Sourceful, where leadership's background made security a given, shows how perceived risk shapes what a company actually does.

Adoption barriers. Change resistance came up at both JEMAC and Dectron. An engineer at JEMAC said the challenge is *"to get people to realise and open their eyes."* A manager at Dectron said *"it is sometimes painful to implement new things."* At JEMAC, a specific barrier was the need to build a quality management system alongside cybersecurity. A manager called this the biggest current challenge: *"we have first of all to establish the quality management system, and then we have to add what we already have done with cybersecurity into that system."* He also raised post-release follow-up as an unsolved problem: *"we need to find a way to really keep an eye on that during the project life cycle."* Leadership mentioned investment cost for new tools as a concern. At Sourceful, adoption barriers were fewer, but the documentation burden was significant.

4.2 Cross-Case Comparison

The three companies sit at different points on a cybersecurity maturity level. JEMAC is the primary case studied through interviews and onsite observation, while Dectron and Sourceful are comparison cases studied through interviews alone. The maturity variation turned out to be the most useful feature of the dataset. The interview base behind the comparison is weighted by design: five participants at JEMAC, the primary case, two at Dectron, and one at Sourceful Energy (Section 3.2).

Theme	JEMAC (primary)	Dectron (comparison)	Sourceful (comparison)
CRA awareness	Limited; relies on QE	Aware but not studied	NIS2 more salient than CRA
Trigger for cybersecurity action	RED Directive (mid-2024)	None yet	Founder background in network security
Main compliance challenge	Standards interpretation	Fast-moving field	Documentation burden; speed
Formal cybersecurity tools used	None ("common sense")	None	OWASP Top 10 cited; internal tools
Framework format preference	Hybrid (checklist + AI + person)	Checklist + automated layer	Continuous AI repo monitor
Role coverage	QE hired; single firmware engineer on Pedaly	One firmware/HW engineer	Founder + small team
Post-release readiness	Partial (RED-DA route)	Not applicable yet	Internal tooling in build
Maturity self-position	Developing (transition)	Starting (threshold)	Established (culture-led)

Table 1 Cross-case comparison of recurring themes across JEMAC, Dectron and Sourceful. Source: author's analysis of the coded interview and observation data.

Dectron is at the threshold. Their products are mostly stand-alone systems with no internet connection, and a manager compared the CRA to other regulations like the RoHS and REACH directives, expecting the same pattern of initial struggle followed by normalisation. An engineer is beginning to think about connected products, but the

company has no cybersecurity tools, guidelines, or frameworks in place. Cybersecurity seems to be understood in principle but absent in practice.

JEMAC looks like they are active transition. The RED Directive forced them to engage with cybersecurity about a year before the interviews. They hired a quality engineer, worked with external consultants from Nemko, and began integrating cybersecurity into their project process. JEMAC now considers cybersecurity from the project start and uses it in sales conversations.

Sourceful has security embedded in its culture from the beginning. Sourceful leadership has a background in network security. Their challenge is not awareness but speed: development timelines measured in days leave little room for thorough security review.

Three codes appeared in all three companies. These were the strongest shared patterns. Low CRA awareness was universal. Every participant had limited knowledge of the CRA specifically. The aspiration to consider cybersecurity early was also universal, though the gap between aspiration and practice varied. Another pattern was that reliance on experience rather than formal tools was shared across all three. None used a cybersecurity decision-making framework, tool, or standard. Decisions depended on what individual people happened to know.

4.2.1 JEMAC Primary Case Observation (Pedaly Project)

The Pedaly Bike Dock Parking project was observed at JEMAC from September 2025 to April 2026 across the four phases of its development cycle. The observation gives the JEMAC interview data a triangulated complement and also shows what the patterns described by participants look like inside a single real product.

Concept and requirements phase. None of the framework's first six decisions were made before the researcher joined the project. There was no CRA classification, no explicit data-scope mapping, and no security requirements written into the product specification. The chosen microcontroller turned out later to lack hardware encryption support.

Architecture and design phase. By late 2025 the team had to retrofit a threat assessment which revealed several gaps. They then had to substitute in alternative controls to take care of these gaps. The retrofits were workable but more expensive at this stage.

Implementation phase. Third-party library vulnerability checks and build hygiene were in place but SBOM and code review were not. Pedaly's firmware was developed by a single engineer with no peer-review path internally, this represented a high risk.

Validation and release phase. JEMAC's cybersecurity work on Pedaly was driven by the Radio Equipment Directive's (RED) delegated act and the EN 18031 radio-equipment cybersecurity standard rather than by the CRA. Technical documentation, residual-risk sign-off, and a five-year support commitment were in place.

Four human-factors patterns came out of the Pedaly observation. Role coverage was thin. The firmware was written by a single engineer with no internal peer reviewer, so design choices that would have benefited from a second pair of eyes did not get them. Leadership engagement was reactive. Management took cybersecurity seriously only after the RED delegated act came into force. Decisions ran ahead of records. The microcontroller choice, the data-scope decision, and several Phase 2 architectural calls were made without written rationale, which forced reconstruction from project documentation when the framework was applied retrospectively. Trade-offs were resolved by retrofit. Where an early decision created a security gap, as with the missing hardware-accelerated crypto engine, the team substituted physical and procedural workarounds rather than reopening the design.

4.3 The Framework

The Cybersecurity-by-Design Decision-Support Framework is the primary artefact of this research. It is made up of the framework diagrams, two conditions-of-use artefacts (Adoption Readiness Checklist and CRA at a Glance), and a twenty-five-question working checklist that carries the maturity calibration in three track columns. The full artefact set is reproduced in Appendix C. This section describes the framework and how each part connects to the findings.

4.3.1 Structure

The framework organises cybersecurity decisions into four development phases: Concept and Requirements, Architecture and Design, Implementation, and Validation and Release. These phases were derived empirically from the product development processes the participants described, rather than taken from a single named lifecycle model. They are not tied to any one method. The four phases fit onto an SME's existing process instead of imposing a new one.

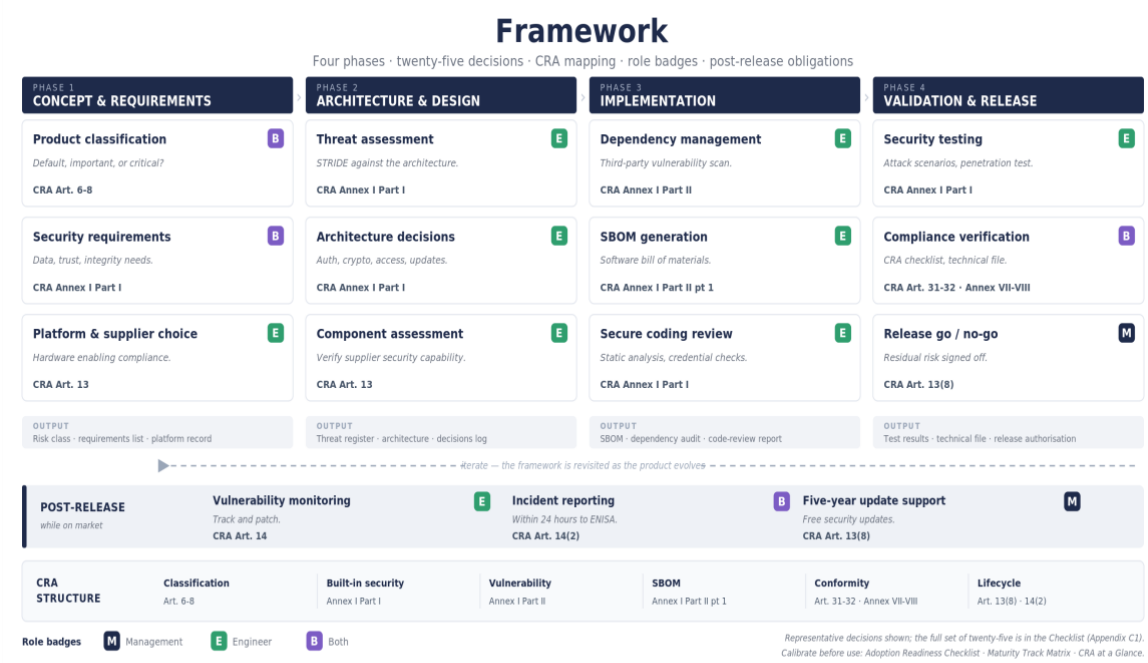


Figure 3 The Cybersecurity-by-Design Decision-Support Framework.

In use, the framework follows five steps.

First, the team works through the Adoption Readiness Checklist (described in Section 4.3.1 below) to confirm the preconditions before using the framework. They then pick a maturity track by reading the three track profiles in the Checklist. Finally, they walk the framework by working through the four phases and twenty-five decisions, with the Checklist's track columns telling them how deep to go on each question. The 'CRA at a Glance' serves as the plain-language bridge to the regulation.

The five steps are sequential but the framework itself is iterative. Each phase contains between five and seven decision points, with the full set captured in a practical checklist of twenty-five questions. Each decision point is framed as a question and mapped to a specific CRA article or annex section.

Each decision also carries a role badge, either M (management), E (engineer), or B (both), which shows who holds primary responsibility during the decision making. The bookend phases carry shared and management decisions, while the middle phases are mainly engineer-led.

A post-release obligations bar sits below the four phases in the framework diagram. It covers vulnerability monitoring, incident reporting, and the commitment to provide security updates. This reflects the CRA's extension of manufacturer responsibility beyond the point of sale. Participants at both JEMAC and Sourceful identified post-release

obligations as a challenge they had not yet solved. A manager at JEMAC described needing to *"find a way to really keep an eye on that during the project life cycle."*

Maturity calibration runs across the framework. The three levels, Starting, Developing, and Established, correspond to the three case companies. Three columns inside the working checklist specify the depth of engagement (In Depth, Default, or Audit) for each of the twenty-five questions at each level.

Track (case example)	Phase 1 Concept	Phase 2 Architecture	Phase 3 Implementation	Phase 4 Validation
Starting (Dectron-type)	6 in-depth	2 in-depth · 5 default	2 in-depth · 3 default	5 in-depth · 2 default
Developing (JEMAC-type)	6 in-depth	7 in-depth	5 in-depth	7 in-depth
Established (Sourceful-type)	1 default · 5 audit	7 audit	5 audit	2 in-depth · 5 audit
Status codes	In depth: answer fully, produce output	Default: industry default, document the assumption	Audit: existing practice covers it, verify and record	

Table 2 Track-depth coding from the Checklist. Depth of engagement for the twenty-five decisions at each maturity track.

Two cross-cutting concerns, governance and human factors, are made operational by the Adoption Readiness Checklist of thirteen yes/no questions answered by the team before the framework is opened on a real product. The checklist functions as a precondition gate, addressing the strongest empirical pattern in the data: no SME in the sample relied on cybersecurity decision-support tools, and Leadership involvement was the most consistent enabler of progress.

4.3.2 CRA Alignment

The framework maps to specific CRA articles and annex sections rather than to high-level category labels. The mapping covers six CRA requirement areas: product classification (Articles 6, 7 and 8), essential cybersecurity requirements (Annex I, Part I), vulnerability handling requirements (Annex I, Part II), conformity assessment and documentation (Articles 31 and 32, Annex VII and Annex VIII), the software bill of materials obligation (Annex I Part II point 1), and lifecycle obligations including the 24-hour incident reporting requirement (Article 14(2)) and the five-year minimum support period (Article 13(8)). Each decision point in the framework diagram and each row in the practical checklist carries its specific CRA tag.

CRA requirement area	Articles / Annex	Framework decisions that address it	Evidence artefact produced
Product classification	Art. 6 · Art. 7 · Art. 8	1.1 classification	Phase 1 Decision Record
Essential cybersecurity requirements	Annex I, Part I	1.3 security requirements · 2.1 threat assessment · 2.2 authentication · 3.3 code review · 4.1 security testing	Phase 2-4 Decision Records
Vulnerability handling	Annex I, Part II	3.1 dependency management · 4.1 security testing · post-release vulnerability monitoring	SBOM · vulnerability log
Conformity assessment & documentation	Art. 31 · Art. 32 · Annex VII · Annex VIII	1.4-1.6 platform/supplier · 2.3 component assessment · 4.2 compliance verification · 4.3 release sign-off	CRA Technical File · Conformity Assessment Walkthrough
Software bill of materials	Annex I Part II point 1	3.2 SBOM generation	SBOM artefact
Lifecycle obligations	Art. 14(2) · Art. 13(8)	Post-release: vulnerability monitoring · 24-hour incident reporting · 5-year update support	Incident Reporting Workflow

Table 3 CRA alignment. Each of the six requirement areas mapped to the articles, the framework decisions that address it, and the evidence artefact produced.

5 Discussion

5.1 Interpretation as the Central Friction

The central finding in this discussion is the difficulty of turning regulatory and standards text into product decisions. Five of the eight participants raised this directly. The challenge spans both the static interpretation problem at JEMAC and the moving-target version an engineer at Dectron described.

This finding is consistent with the literature. Metin, Özhan and Wynn (2024) found that frameworks like ISO 27001 and NIST CSF require skilled security experts to interpret. Ruohonen (2025) traced the same pattern across secure-by-default contexts, and Del-Real, De Busser and van den Berg (2024) showed that Security by Design itself lacks the implementation logic that would make it easy and directly usable.

The framework responds to this in three ways. First, it does not quote regulatory text. Each of the twenty-five decisions is framed as a plain-language question. Second, the article-level CRA mapping in each decision and the plain-language CRA at a Glance card together let a team work from the question downward to the regulation, instead of the other way around. Also, the CRA at a Glance card is an interpretive aid for design decisions, not legal advice, and it does not replace formal conformity assessment. As CRA harmonised standards are published, the interpretations underneath each decision are reviewed. The article-level tags themselves stay stable because they refer to the regulation's permanent structure. The framework therefore offers a structured, article-referenced route into the regulation rather than a guarantee of compliance. Although the mapping reflects a careful reading of the regulation's structure, its correctness has not yet been confirmed by a notified body or legal authority. That confirmation is an open question which could be carried into future work.

What this implies is that interpretation is not a side concern. It is a very important need of any framework that wants to be used by SMEs, especially because they largely operate without dedicated cybersecurity staff. A framework that asks practitioners to interpret regulatory text on their own will fail in the same way that ISO 27001 and NIST CSF have failed to reach SMEs. This framework treats interpretation as the primary value it adds, not as an assumption about its users.

This is how the study answers the second research question. It supports CRA alignment not by guaranteeing compliance but by giving SMEs a structured, article-referenced route from a plain-language decision to the regulation, an alignment that remains proposed rather than validated until a notified body or legal authority confirms the mapping.

5.2 Maturity as the Determining Variable

The three case companies sit at different points on a cybersecurity maturity gradient. Dectron is at the threshold, where products are mostly unconnected and cybersecurity has not yet been forced into the process. JEMAC is in active transition, triggered by the RED Directive about a year before the interviews. Sourceful operates with security embedded in its culture from the start, driven by Sourceful leadership's long background in network security.

The same regulatory pressure, the CRA, will land on all three companies in 2027. However, what they need from a framework to this effect is not the same. Dectron needs an introduction to the territory and a default for everything outside its current connected-product experience. JEMAC needs help formalising and documenting the practices it has already started building. Sourceful needs an audit tool against existing practice. A single, uniform framework would either overwhelm Dectron, under-serve JEMAC, or bore Sourceful.

This variation drives one of the framework's central design decisions. All twenty-five questions apply at every maturity level with only the depth of engagement changing. The Checklist's three track columns specify, for each question, whether a team at the Starting, Developing or Established track should answer in depth, apply an industry default, or audit existing practice. The three tracks correspond directly to Dectron, JEMAC and Sourceful, but the labels are generic so the framework can travel beyond the case companies.

Mihelic, Hovelja and Vrhovec (2025) show that secure-software-engineering adoption works differently before and after initial uptake. Social norms and risk awareness drive pre-adoption behaviour, while ease of use and attitude sustain post-adoption. The Checklist's three track columns are the operational answer to that finding.

The maturity theme also accommodates the unresolved debate among the four root-cause accounts of SME cybersecurity failure (literacy, resources, culture, outreach). The framework does not pick between them. It calibrates to whichever one is binding for the team at the time. A literacy-limited SME is at the Starting track, a resource-constrained SME is at Developing, and a culture-driven SME is at Established.

The gap between aspiration and practice, which appears across all three companies in different forms, is the symptom of where a team sits on this gradient. All three companies aspire to integrate cybersecurity from the start but only Sourceful seems to actually do it. JEMAC is in the process of closing the gap and a manager said so directly: "*right now, the team starts in the middle of the project, even though starting earlier would be better*". Dectron has not yet started. The framework does not treat the gap as a failure to be eliminated. It treats it as a measurable distance that the maturity track helps a team work through.

JEMAC's middle position on the gradient is borne out by the Pedaly observation. The team has crossed the threshold but has not yet formalised practice.

The three-level structure invites an obvious concern. With three case companies and three tracks, each track corresponding to one company, it could look as though the tracks were fitted to the sample. But two points stabilise the design against that. First, the three-level structure sits within an established convention in maturity-model literature. SAMM (OWASP, 2020) uses four levels but treats the first as a placeholder for organisations with no formal practice, leaving three substantive levels. BSIMM (Synopsys, 2024) clusters observed activities into three implementation tiers. NIST CSF 2.0 (NIST, 2024) retains a tiered structure for implementation. The framework's Starting, Developing, and Established tracks sit comfortably within this convention. Second, the tracks are defined by depth of engagement against the twenty-five decisions, not by company identity. Any SME walking the Adoption Readiness Checklist self-places onto a track without the case companies being involved. The case companies are examples of the tracks, they do not constitute them.

Putting all these together, these patterns answer RQ1. Cybersecurity decision-making in these SMEs is concentrated at a few design moments, driven mostly by personal experience rather than formal tools. They are entered reactively rather than from the start, and organisational maturity rather than company size usually sets how far each team has come.

5.3 Leadership and the Conditions for Adoption

The cross-case finding established in Section 4.2, that leadership involvement is the single most consistent enabler, drives the 'conditions of use' logic in the framework. At JEMAC, a manager described what changed, He said "*we did not work that much on cybersecurity before we hired a special person for it.*" That single hiring decision was the visible turning point. At Sourceful, leadership's background made the same effect operate by default. At Dectron, the absence of an equivalent leadership moment is itself the explanation for why cybersecurity remains dormant.

This finding aligns directly with Odujinrin (2023), who found that top management involvement is the single most important enabler of security compliance in US small businesses. It is reinforced by Ludin et al. (2025), who locate management support and culture as the primary determinants of SME cybersecurity programme effectiveness. The pattern across methods and contexts is consistent. Technical measures, training, and tools do not produce lasting behaviour change without leadership actively endorsing them.

The framework operationalises this finding through the Adoption Readiness Checklist (described in Section 4.3.1). The five governance questions include explicit leadership commitment, a named owner, scheduled time, access to external expertise, and an agreement that the release date can move if residual security risk is too high. A no answer marks a gap that the framework will not close on its own. Three or more no answers signal that running the framework would produce records that do not stick.

The checklist treats leadership participation not as a condition the SME has to confirm before the framework is useful, which is unusual, since NIST CSF, ISO 27001 and OWASP SAMM all assume the conditions are already in place. The framework makes the conditions clear and gives the team a concrete next step if they are not.

A related sub-theme that appears in the data is the role of the named owner. Before JEMAC hired its quality engineer, cybersecurity work was dispersed across people and lacked accountability. The same pattern surfaces in the literature. Kudriavtseva and Gadyatskaya (2023) note that secure SDLC methodologies neglect the organisational scaffolding that makes them work. A framework alone is not enough. A framework with a named owner is.

The Pedaly observation provides evidence. JEMAC management engaged with cybersecurity on the project only after both the RED trigger and the named driver were in place. Either one alone would not have been enough (Section 4.2.1).

5.4 Two Surfaces, One Framework

The clearest split in the data was between what managers and engineers wanted from a decision-support tool. Managers wanted scannable overviews and go or no-go signals. JEMAC leadership described their ideal as a system where you "*shove in all the information"* and get back a list of "*where we comply and where we do not comply*." A manager at Dectron wanted a checklist that simplifies the work.

Engineers wanted technical depth and queryable interfaces. An engineer at JEMAC wanted "*a collection of vector embeddings in a Qdrant database that I can query with my retrieval-augmented generation (RAG) system.*" Sourceful leadership wanted an AI agent that continuously monitors code repositories against known vulnerabilities.

The framework's two principal surfaces, the framework diagram and the working checklist, respond to this split directly. The diagram is the strategic view. The checklist is the operational one. Both are anchored in the same twenty-five decisions, so a manager scanning the diagram and an engineer working through the checklist are looking at the same content at different resolutions.

This dual-surface choice resonates with what Khadka and Ullah (2025) have argued from cognitive-load theory. Decisions made under time pressure, incomplete information and competing priorities benefit from structured environments that present information at the right level of abstraction. A single dense surface either overwhelms the manager or under-serves the engineer. The dual-surface design is the framework's answer to cognitive load.

What the dual-surface choice does not solve is the AI-agent preference that appeared most strongly among engineers and at the hybrid position. The framework is currently a structured set of artefacts, not an automated tool.
The third research question is answered by these two themes. The human and organisational factors a framework must account for are leadership involvement and a named owner on

the management side. The Adoption Readiness Checklist (Section 4.3.1) and the dual-surface design address this directly.

5.5 What the Framework Contributes Beyond Existing Frameworks

Five cybersecurity frameworks were repeatedly referenced in the interviews, the literature, or the supervisor's progress-meeting questions: NIST CSF 2.0, ISO 27001, OWASP SAMM, STRIDE, and LCCI (Pawar and Palivela, 2022). Each of them is valuable in its intended context. None of them addresses the SME design-stage problem under the CRA.

Framework	Design-stage support	SME fit	Article-level CRA mapping	Maturity calibration	Human factors as precondition	Empirical grounding in SME data
NIST CSF 2.0	Partial	No	No	No	No	No
ISO 27001	No (governance)	No	No	No	No	No
OWASP SAMM	Yes (software only)	Partial	No	Yes	No	No
STRIDE	Partial (threat modelling)	Partial	No	No	No	No
LCCI (Pawar & Palivela, 2022)	No (prioritisation)	Yes	No	No	No	No
This framework	**Yes**	**Yes**	**Yes**	**Yes**	**Yes**	**Yes**

Table 4 *Five cybersecurity frameworks and this thesis's framework, compared on the criteria that define the SME design-stage problem under the CRA.*

The framework occupies the intersection that none of these five frameworks covers.

5.6 Evaluation of the Framework

The framework was evaluated at the primary case. Five practitioners at JEMAC reviewed the framework and its artefacts and then completed a structured questionnaire. Between them they placed the company across all three maturity tracks, from Starting to Established, which gave the single case a useful internal spread of viewpoints. Each statement was rated from 1 (strongly disagree) to 10 (strongly agree) across four areas, clarity, utility, relevance, and adoption, with written comments at the end of each area. The procedure follows the evaluation strategy set out in Section 3.7, and the questionnaire and coded responses can be found in the appendices.

Evaluation area	Items	Mean (1–10)
Clarity	8	7.4
Utility (overall)	6	8.2
Utility by phase	4	7.6
Relevance	6	7.5
Supporting artefacts	5	7.8
Adoption	5	7.0
Overall rating	2	7.7

Table 5 Mean practitioner ratings by evaluation area (five JEMAC respondents, 1 to 10 scale).

The overall picture is positive, though not so uniform. Of the four areas, utility scored the highest, at 8.2. The practitioners felt that the framework would make their cybersecurity decisions more consistent, would make it easier to trace why a decision was made, and would help them show a customer or an auditor that cybersecurity had been considered. In short, they valued it most for making decisions consistent and defensible, and that is exactly the gap the interviews had pointed to.

Clarity came next, at 7.4. The framework diagram, the four-phase sequence, and the Adoption Readiness Checklist were all easy to follow. The one item that lagged, at 6.2, was whether each checklist question makes its meaning clear, and an engineer explained their low score: several of the twenty-five questions ask for two things at once, so a single rating cannot do them justice. A manager raised a related point. They felt the line between the Developing and Established tracks was vague enough that a team could reasonably place itself on either side.

Relevance scored 7.5, but here the spread between respondents tells us more than the average does. Each person's rating followed their own sense of where JEMAC sits on the maturity scale. Two managers, who see the company as further along, gave the highest ratings overall, at 8.0 and 8.1. One engineer, the only one who placed JEMAC at the Starting level, gave the lowest, at 6.4. Their comments make the reason clear. To them the framework reads as a software document. Secure update, software bill of materials, and vulnerability handling are all treated as code problems, and the hardware and supply-chain decisions they deal with every day are missing, things like locking down the debug interface, choosing a secure element, and provisioning keys on the production line. They also noted that for the radio modules their team ships, it is the Radio Equipment Directive rather than the CRA that decides market access. This fits the maturity argument in Section 5.2. The framework works best for teams that are already some way up the gradient, and a Starting-level team whose risk sits mostly in hardware needs more support than the current version offers.

The fact that five people from the same company placed it on three different tracks is itself telling. Self-placement reflects how mature each person feels the company is from where

they sit, rather than a single fact about the company. A manager answered from the governance and process side, which at JEMAC is fairly developed, while an engineer answered from the hardware and supply-chain side, where there is still very little in place. Maturity within one SME is therefore uneven from one function to the next, and this spread is itself the evidence behind the blurred line between the Developing and Established tracks that a manager pointed to under clarity.

Adoption scored the lowest, at 7.0, although the problem was capacity rather than willingness. The two weakest items, both at 6.2, were whether the framework takes an acceptable amount of time and whether the team has the skills to use it without outside help. A manager put it plainly. The real barrier is engineering time when a delivery is under pressure, not a lack of buy-in, and what would help most is a short, must-do set of decisions for each phase, so that a team in a hurry knows what it cannot afford to skip. Leadership support, on the other hand, scored well. Leadership said that backing from the top would not be the problem, and that what he was missing was a clear sense of what adopting the framework would cost in people and time.

The written comments pointed to a clear set of refinements, all of which were recorded against the framework. Three are small and textual, and were easy to act on: splitting the questions that ask for two things at once, sharpening the short definitions that separate the maturity tracks, and adding owner, due date, and status fields to the Phase Decision Record so the decisions are not filled in once and then forgotten. The other three are larger and sit outside what this version can cover, but the evaluation shows they are needed: a decision point for suppliers and the software bill of materials, a thread for runtime monitoring and vulnerability handling after release, and a hardware and provisioning track for Starting-level teams whose risk lies mainly in the silicon. These larger additions are carried forward in the future research agenda in Section 6.4.

The evaluation has clear limits. It was done at the primary case only, with five practitioners from one company, so it tests the framework against a single setting rather than the full range of SMEs the CRA reaches. The ratings are also reactions to reviewing the framework, not a measure of how it performs on a live project over time. And since the researcher who built the framework also ran the questionnaire, the embedded position set out in Section 3.8 is worth repeating here. The mix of maturity and roles among the five does strengthen the result, but it is no substitute for evaluation at the comparison cases or by independent experts, both of which are listed as future work in Section 6.4.

6 Conclusion

6.1 Contributions of the Work

The first contribution is empirical. The eight cleaned interviews across JEMAC, Dectron, and Sourceful Energy produced 178 coded segments, 148 from the interviews and 30 from observation. At the primary case, the interview findings were triangulated by onsite observation of the product development life cycle at JEMAC. As far as the author is aware, this is one of the first empirical accounts of how Swedish SMEs are responding to the Cyber Resilience Act before its 2027 enforcement date. The dataset shows low CRA awareness across all three companies, a split by role in the kind of decision support that was wanted, and a maturity gradient that runs from a company yet to engage with the regulation to one whose security culture was already in place before it.

The second contribution is the framework itself; the first design-stage cybersecurity decision-support framework grounded in SME interview data, with its composition set out in Section 4.3.

The third contribution is theoretical. Five bodies of literature have largely developed on their own: decision-support systems, secure-by-design, human factors, SME cybersecurity, and CRA compliance. The framework sits at their intersection, and it treats human and organisational factors as preconditions for using it, not as extra content added on top.

6.2 Practical Implications

The framework is built to be picked up by three groups of users.

For SME leadership (CEO, founder, product owner), the Adoption Readiness Checklist gives a thirty-minute conversation that exposes whether a product development team is well positioned to use the framework at all. The framework refuses to start until five governance conditions are honestly in place.

For SME engineering teams, the Checklist gives the operational shape. Twenty-five questions across four phases, walked through in order, with depth calibrated by the maturity track. The output is a record of decisions that supports CRA conformity.

For supervisors, consultants, and policy-makers working with SMEs, the framework gives a shared vocabulary for SME-CRA conversations. The CRA at a Glance card translates regulatory text into product-development decisions without paraphrasing it away.

6.3 Limitations

The eight interviews are unevenly distributed across the three cases: five at JEMAC, two at Dectron, and one at Sourceful Energy. The JEMAC weight is intentional because JEMAC is the primary case where extended access enabled both interviews and participant-

observation, and the five participants cover the range of roles relevant to product development.

The findings and the framework rest on a sample that is small and culturally specific. Three case companies, all Swedish, in tech, electronics, and energy sectors. Variation is real across the three but does not represent the full range of European SMEs the CRA affects. Healthcare, automotive, and food-sector SMEs may face the same regulation under different operational constraints. Onsite observation that triangulates the interview data is confined to JEMAC, the primary case. Cross-case observation at Dectron and Sourceful would strengthen the empirical base but sits outside the scope of this research and is named as a future-study direction. The framework's transferability rests on the variation in product type captured in the three cases, not on a full EU-wide coverage.

The evaluation is bounded in the same way. The framework was assessed by five practitioners at the primary case through a questionnaire. That tests it against one organisational context, and as a reviewed document rather than in sustained use on a live project. Evaluation at the comparison cases, by independent experts, and over the life of a real project remains open, and could be a future study area.

The CRA itself is a moving target as harmonized standards are still being published. The framework will need maintenance as those standards are released.

Finally, the thesis was written by one person, working with the primary case companies they had access to through existing professional relationships. At the primary case (JEMAC), the researcher held the role of quality engineer during the observation period and was involved in the cybersecurity workstream of the observed project. The observation is therefore participant-observation, with the researcher both shaping and recording cybersecurity decisions. That access made the research possible but creates conditions for confirmation bias. The checks applied are a traceability review mapping each Chapter 4 claim to its source.

6.4 Directions for Future Research

The framework has been evaluated at the primary case, where five JEMAC practitioners rated it against utility, clarity, relevance, and adoption. The first direction for future work is to extend that evaluation beyond a single company, to the comparison cases and to a wider range of SME contexts, so the framework is tested where its assumptions are most likely to be challenged. The Starting-level, hardware-focused feedback in the evaluation already points to one such context.

The second direction is external expert review by a notified body, legal practitioner, or EU cybersecurity policy researcher to confirm or correct the regulatory alignment claims.

Another direction is longitudinal deployment paired with cross-case observation. A six-month deployment with one or two SMEs walking through the framework on an actual

product would produce the deployment evidence the framework cannot generate on its own.

Finally, there could be some opportunities to expand the scope of the research to SMEs in other sectors like healthcare, automotive, and food-related industries, and integration with adjacent regulations such as the Radio Equipment Directive, NIS2, and GDPR.

References

Akinsanya, O.O. (2025) ‘Security by design: a risk-based framework for cybersecurity compliance and critical infrastructure protection’, International Journal of Information Security, 24, article 58.

Ashenden, D. and Lawrence, D. (2016) ‘Can we sell security like soap? A new approach to behaviour change’, IEEE Security and Privacy, 14(2), pp. 54–62.

Awan, S.H. and Alam, M. (2025) ‘Cybersecurity threats and defensive strategies for small and medium firms: a systematic mapping study’, Administrative Sciences, 15(12), article 481.

Awan, S.H., Alam, M., Khan, S. et al. (2026) ‘A generative AI-driven cybersecurity framework for SME software development: an ANN-ISM approach’, Scientific Reports, 16, article 37614.

Benjamin, M. et al. (2024) ‘Digital transformation in SMEs: identifying cybersecurity risks and resilience strategies’, Global Journal of Engineering and Technology Advances, 21(1), pp. 118–133.

Boehm, B.W. (1981) Software engineering economics. Englewood Cliffs, NJ: Prentice Hall.

Braun, V. and Clarke, V. (2006) ‘Using thematic analysis in psychology’, Qualitative Research in Psychology, 3(2), pp. 77–101.

Del-Real, C., De Busser, E. and van den Berg, B. (2024) ‘Shielding software: a PRISMA-driven systematic literature review of security and privacy by design’, Computers and Security, 145, article 103989.

Eian, I.C., Ka Yong, L., Hasmaddi, N. and Fatima-tuz-Zahra (2020) ‘Security modules in software development lifecycle phases’, arXiv preprint, arXiv:2012.05540.

El-Hajj, M. and Mirza, F. (2024) ‘Protecting small and medium enterprises: a specialised cybersecurity risk assessment framework and tool’, Electronics, 13(19), article 3910.

ENISA (2021) Cybersecurity for SMEs: challenges and recommendations. Heraklion: European Union Agency for Cybersecurity.

European Commission (2003) Commission Recommendation 2003/361/EC of 6 May 2003 concerning the definition of micro, small and medium-sized enterprises. Official Journal of the European Union, L 124, pp. 36–41.

European Commission (2022) Proposal for a regulation on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). COM(2022) 454 final. Brussels: European Commission.

European Commission (2024) Cyber Resilience Act. Available at: https://digital-strategy.ec.europa.eu/en/library/cyber-resilience-act (Accessed: 28 Jan 2026).

Fagan, M., Megas, K.N., Watrobski, P., Marron, J., Cuthill, B., Lemire, D. and Hoehn, B. (2024) Product development cybersecurity handbook: concepts and considerations for IoT product manufacturers. NIST CSWP 33. Gaithersburg, MD: National Institute of Standards and Technology.

François, J., Arduin, P.-E. and Merad, M. (2023) 'Classification of decision support systems for cybersecurity', HAL Open Science, hal-04443213.

Granata, D. and Rak, M. (2024) 'A systematic literature review and comparison of automated threat modelling techniques', Journal of Systems and Software, 215, article 112084.

Hevner, A.R., March, S.T., Park, J. and Ram, S. (2004) 'Design science in information systems research', MIS Quarterly, 28(1), pp. 75–105.

Jiang, S., Meng, W., Shang, T., Oo, A.M., Minh, T.N., Lim, K.L. and Sikdar, B. (2025) 'MITRE ATT&CK applications in cybersecurity and the way forward', arXiv preprint, arXiv:2502.10825.

Khadka, R. and Ullah, S. (2025) 'Human factors in cybersecurity: a comprehensive framework for understanding and mitigating human-related vulnerabilities', Journal of Cybersecurity and Privacy, 5(1), article 9.

Kudriavtseva, A. and Gadyatskaya, O. (2023) 'Secure software development methodologies: a multivocal literature review', arXiv preprint, arXiv:2211.16987.

Lincoln, Y.S. and Guba, E.G. (1985) Naturalistic inquiry. Newbury Park, CA: Sage.

Ludin, N.H.M., Mohd, S. and Fauzi, M.A. (2025) 'Enhancing cybersecurity programs in small and medium enterprises: a systematic literature review', International Journal of Advanced Computer Science and Applications, 16(9), pp. 365–377.

Metin, B., Özhan, U. and Wynn, M. (2024) 'Digitalisation, cybersecurity and an operational framework for small and medium businesses', International Journal of Business Information Systems, 45(3), pp. 367–391.

Mihelic, A., Hovelja, T. and Vrhovec, S. (2025) ‘Factors influencing the adoption of secure software engineering practices in pre-adoption and post-adoption phases’, Scientific Reports, 15, article 27024.

NIST (2024) The NIST cybersecurity framework (CSF) 2.0. NIST CSWP 29. Gaithersburg, MD: National Institute of Standards and Technology.

Odujinrin, O. (2023) Promoting effective cybersecurity policy compliance in small businesses. Doctoral dissertation. Walden University.

OWASP (2020) Software Assurance Maturity Model (SAMM) v2.0. Available at: https://owaspsamm.org/ (Accessed: 28 May 2026).

Pawar, S. and Palivela, H. (2022) ‘LCCI: a framework for least cybersecurity controls to be implemented for small and medium enterprises’, International Journal of Information Management Data Insights, 2(1), article 100080.

Peffers, K., Tuunanen, T., Rothenberger, M.A. and Chatterjee, S. (2007) ‘A design science research methodology for information systems research’, Journal of Management Information Systems, 24(3), pp. 45–77.

Power, D.J. (2008) ‘Decision Support Systems: A Historical Overview’, in Burstein, F. and Holsapple, C.W. (eds.) Handbook on Decision Support Systems 1. Berlin: Springer, pp. 121–140.

Rawindaran, N., Jayal, A., Prakash, E. and Hewage, C. (2023) ‘Perspective of SMEs and their relationship with government in overcoming cybersecurity challenges and barriers in Wales’, International Journal of Information Management Data Insights, 3(2), article 100198.

Risto, E., Sethi, M. and Katara, M. (2025) ‘Effects of the Cyber Resilience Act on industrial equipment manufacturing companies’, arXiv preprint, arXiv:2505.14325.

Rombaldo Junior, S., Becker, I. and Johnson, S.D. (2025) ‘A systematic review of SME cybersecurity’, arXiv preprint, arXiv:2309.17186.

Ruohonen, J. (2025) ‘SoK: the design paradigm of safe and secure defaults’, arXiv preprint, arXiv:2412.17329.

Ruohonen, J. and Timmers, P. (2025) ‘Vulnerability coordination under the Cyber Resilience Act’, arXiv preprint, arXiv:2412.06261.

Saltzer, J.H. and Schroeder, M.D. (1975) ‘The protection of information in computer systems’, Proceedings of the IEEE, 63(9), pp. 1278–1308.

SBS (2023) Cyber Resilience Act: position paper from an SME perspective. Brussels: Small Business Standards.

Shimizu, T. and Hashimoto, M. (2025) 'Vulnerability management chaining: an integrated framework for efficient cybersecurity risk prioritization', arXiv preprint, arXiv:2506.01220.

Sukumar, A., Mahdiraji, H.A. and Jafari-Sadeghi, V. (2023) 'Cyber risk assessment in small e-tailing SMEs: a multilevel decision-making approach', Risk Analysis, 43(6), pp. 1259–1279.

Synopsys (2024) BSIMM15: Building Security In Maturity Model. Mountain View, CA: Synopsys.

Teichmann, F. (2026) 'The Cyber Resilience Act as a new paradigm for product security: a compliance roadmap', International Cybersecurity Law Review, 7(1), pp. 45–68.

Tetteh, A.K. (2024) 'Cybersecurity needs for SMEs', Issues in Information Systems, 25(1), pp. 235–246.

ValdesRodriguez, P.I., Hochstetter-Diez, J., Díaz-Arancibia, J. and Cadena-Martínez, R. (2023) 'Towards the integration of security practices in agile software development: a systematic mapping review', Applied Sciences, 13(7), article 4578.

Yin, R.K. (2018) Case study research and applications: design and methods. 6th edn. Thousand Oaks, CA: Sage.

Appendix A — Data Collection Instruments

A1 Interview Guide

Reproduced as issued to interview participants.

Interview Details

Participant	
Role / Title	
Date	
Duration	
Format	Online (recorded with consent)

Section A: Background and Role

Purpose: *Understand the participant's position and involvement in product development.*

1. Can you briefly describe your role at your company and what you are responsible for in the product development process?
2. How long have you been working in this role, and what is your background?
3. How would you describe the typical product development process at your company, from idea to finished product?

Section B: Current Cybersecurity Practices

Purpose: *Map how cybersecurity is currently handled during product development.*

4. When you think about cybersecurity in the products your company develops, what comes to mind? How would you describe the role cybersecurity plays in your development work today?
5. At what point in the development process do cybersecurity considerations typically come up? Is it something discussed early on, or does it tend to emerge later?
6. Are there any specific tools, guidelines, or frameworks you currently use to guide cybersecurity decisions during development?
7. Can you walk me through a recent example where a cybersecurity-related decision had to be made during a project? What happened, and how was it resolved?
8. Are there any internal documents, such as product roadmaps, process descriptions, or risk logs, that include cybersecurity considerations?

Section C: Decision Points and Constraints

Purpose: *Identify where cybersecurity decisions occur, what makes them difficult, and what constraints shape them.*

9. In your experience, what are the key moments during product development where cybersecurity decisions need to be made? For example, choosing a communication protocol, deciding what data to encrypt, or selecting an authentication method.
10. What makes those decisions difficult? Is it a lack of information, competing priorities, time pressure, or something else?
11. How do you currently weigh cybersecurity against other concerns like cost, time to market, or product functionality?
12. Are there situations where cybersecurity decisions are postponed or skipped altogether? If so, what usually causes that?
13. Do you feel you have enough knowledge and resources to make confident cybersecurity decisions during development? If not, what is missing?

Section D: Regulatory Awareness and the Cyber Resilience Act

Purpose: *Gauge awareness of the CRA and how regulatory requirements affect development decisions.*

14. Are you familiar with the EU Cyber Resilience Act? If so, what is your understanding of what it requires from companies like yours?
15. Has the CRA or any other cybersecurity regulation influenced how you approach product development so far?
16. What concerns, if any, do you have about meeting the CRA's requirements? Where do you see the biggest challenges for your company?
17. If you had to prepare for CRA compliance today, what would be the first thing you would need help with?

Section E: Decision Support Needs

Purpose: *Understand what kind of structured support would be useful for cybersecurity decisions during product development.*

18. If you had access to a structured guide or framework that helped you make cybersecurity decisions during the design stage, what would it need to look like to be useful to you?
19. Would it be more helpful as a checklist, a set of questions to work through, a decision tree, or something else entirely?
20. What information would it need to provide? For instance, threat categories, regulatory requirements, cost-benefit guidance, or prioritisation criteria?

21. How would it need to fit into your current way of working? Would it need to be part of an existing tool, a standalone document, or something integrated into meetings?
22. Is there anything that would make such a framework difficult to adopt at your company? For example, time constraints, lack of buy-in, or unfamiliarity with the concepts?

Closing

Is there anything else you would like to add about how cybersecurity decisions are made at your company, or anything you think would be important for this research?

Thank you for your time. Your input is very valuable for this research. I may follow up later in the project to get your feedback on the framework once it has been drafted, if you are willing.

A2 Information for Participants

Issued to each participant before consent.

What is the purpose of the project?

The purpose of this study is to understand how small and medium-sized enterprises make cybersecurity decisions during product development, what challenges come up, and what kinds of support would be useful. The study is part of a master's thesis at Linnaeus University.

How will the interview be conducted?

The interview will last approximately 30 to 45 minutes and will be conducted online via Teams or depending on what suits you best. The questions will cover your role, how cybersecurity comes up in your work, and what kind of guidance you would find helpful. There are no right or wrong answers. You may choose not to answer any question at any time.

Possible risks of participating

There are no known risks associated with participating. You will not be identifiable in the study's results or in the final thesis.

What will happen to my data?

The interview will be recorded and transcribed. After transcription, the recording will be deleted. The transcript will be anonymised so that neither you nor your organisation can be identified. Any collected material will only be used for this study. The signed consent form will be stored separately and deleted after the study is completed.

How will I receive the results?

The results will be presented in a master's thesis at Linnaeus University. The thesis will be published in DiVA, where it will be publicly available.

Participation is voluntary

Your participation is voluntary. You may withdraw at any time without providing a reason and without any negative consequences.

Contact

If you have any questions about the study, you may contact:

Kwabena Agyei Sasu-Boakye
Email: kwabena.sasuboakye@jemac.se

Supervisor: Hemant Ghayvat
Email: hemant.ghayvat@lnu.se

A3 Consent to Participate

Signed by each interview participant before recording.

I have read the written information about the study and will also receive verbal information in connection with the interview. I have had the opportunity to ask questions to the person responsible for the study.

By signing this consent form, I agree to participate in the study. This also means that I consent to the interview being recorded and to my data being processed in the manner described in the information for participants.

Participant name	**Date**
Signature	

Appendix B — Coded Data

B1 Codebook

65 codes grouped into 28 themes across the three research questions; the interview analysis drew on 50 of these codes within 15 themes. Source: Interview_Coding.xlsx, Codebook sheet.

Code	Description	Theme	RQ
CYBER_LATE	Cybersecurity introduced late or retrofitted into existing products	Timing of cybersecurity integration	RQ1
CYBER_EARLY	Cybersecurity considered from the very start of development	Timing of cybersecurity integration	RQ1
INTEGRATED_PROCESS	Cybersecurity embedded into the normal design/QA process, not separate	Integration into development workflow	RQ1
MILESTONE_CHECKPOINTS	Cybersecurity decisions tied to project milestones or gates	Integration into development workflow	RQ1
RISK_ASSESSMENT_DRIVER	Risk assessment used to identify cybersecurity gaps and actions	Decision mechanisms	RQ1
GAP_ANALYSIS	Identifying gaps between current state and compliance requirements	Decision mechanisms	RQ1
PLATFORM_CHOICE	Choosing hardware/software platforms that enable compliance from the start	Decision mechanisms	RQ1
SUPPLIER_DEPENDENCY	Reliance on component suppliers for cybersecurity capability	Decision mechanisms	RQ1
EXPERIENCE_OVER_TOOLS	Decisions based on experience and common sense rather than formal tools	Decision mechanisms	RQ1
CHECKLIST_PREFERENCE	Preference for checklist or go/no-go list format	Preferred framework format	RQ1
AI_AGENT_PREFERENCE	Preference for AI-based, automated, or agentic decision support	Preferred framework format	RQ1

RAG_SYSTEM	Desire for queryable knowledge base with interpreted standards	Preferred framework format	RQ1
COMPLIANCE_DASHBOARD	Desire for system that shows comply/not-comply status automatically	Preferred framework format	RQ1
OWASP_REFERENCE	OWASP Top 10 or similar concrete checklist as model for framework	Preferred framework format	RQ1
CRA_LOW_AWARENESS	Limited personal knowledge of CRA specifics, reliance on others	Regulatory awareness	RQ2
CRA_CHANGED_PROCESS	CRA or RED has changed how the company approaches product development	Regulatory impact on practice	RQ2
RED_TRIGGER	RED Directive as the initial trigger for cybersecurity awareness	Regulatory impact on practice	RQ2
CE_MARKING_LINK	CRA/cybersecurity tied to CE marking and market access	Regulatory impact on practice	RQ2
INTERPRETATION_DIFFICULTY	Difficulty interpreting standards and translating regulations into actions	Compliance challenges	RQ2
SELF_VS_EXTERNAL_CERT	Uncertainty about when self-assessment vs external certification is needed	Compliance challenges	RQ2
CUSTOMER_UNAWARE	Customers not yet asking about or understanding CRA requirements	Compliance challenges	RQ2
SUPPLY_CHAIN_PRESSURE	Anticipation that large customers will push CRA requirements down the chain	Compliance challenges	RQ2
COMPETITIVE_ADVANTAGE	Early cybersecurity compliance seen as market differentiator	Strategic response to regulation	RQ2
DOCUMENTATION_BURDEN	CRA documentation and reporting requirements seen as overhead	Compliance challenges	RQ2
NIS2_OVERLAP	Confusion or overlap between CRA and NIS2 requirements	Regulatory awareness	RQ2
RESOURCE_CONSTRAINT	Small team, limited people, everyone does multiple roles	Resource constraints	RQ3

KNOWLEDGE_BUILDING	Team gradually building cybersecurity knowledge over time	Organisational learning	RQ3
SECURITY_CULTURE	Security as part of organisational culture, not just tooling	Organisational learning	RQ3
TIME_PRESSURE	Speed of development creating tension with thorough security practice	Competing priorities	RQ3
TIME_TO_MARKET_TRADEOFF	Willingness to launch with incomplete cybersecurity and patch later	Competing priorities	RQ3
COST_NOT_BARRIER	Cost of cybersecurity not seen as a major barrier	Competing priorities	RQ3
UX_VS_SECURITY	Tension between user experience simplicity and security requirements	Competing priorities	RQ3
CHANGE_RESISTANCE	Difficulty getting people to adopt new ways of working	Adoption barriers	RQ3
QMS_DEPENDENCY	Need to establish quality management system before or alongside cybersecurity	Adoption barriers	RQ3
LIFECYCLE_MONITORING	Challenge of ongoing post-release vulnerability monitoring	Adoption barriers	RQ3
LEADERSHIP_DRIVER	CEO or management driving cybersecurity adoption	Organisational enablers	RQ3
LAYERED_ACCESS	Layered security approach, limiting access based on role	Security practices	RQ3
ISOLATED_ENVIRONMENTS	Separate dev/staging/production environments for security	Security practices	RQ3
INVESTMENT_CONCERN	Cost of adopting new tools or systems as a concern	Adoption barriers	RQ3
INITIAL_SKEPTICISM	Leadership initially skeptical about cybersecurity value before recognising benefits	Organisational learning	RQ3
EXTERNAL_EXPERTISE	Reliance on external consultants or third parties for cybersecurity knowledge	Decision mechanisms	RQ1
PRAGMATIC_WORKAROUND	Finding creative workarounds when full compliance is not immediately possible on a given platform	Competing priorities	RQ3

SECURITY_MINDSET	Accepting that no system is fully secure and planning for incidents rather than aiming for perfection	Organisational learning	RQ3
PROACTIVE_TOOLING	Building internal tools to manage security processes like incident reporting and onboarding	Security practices	RQ3
LOW_PERCEIVED_RISK	Products not connected to internet, cybersecurity risk seen as minimal	Risk perception	RQ3
REGULATION_NORMALISATION	New regulations expected to normalise over time, compared to RoHS/REACH adoption	Organisational learning	RQ2
SECURITY_FOR_ALL	Advocating security thinking even for non-connected or low-risk products	Security practices	RQ3
COMPONENT_SELECTION	Cybersecurity affecting hardware component selection decisions	Decision mechanisms	RQ1
PHYSICAL_ACCESS_CONTROL	Using physical access restrictions as a security measure when digital controls are limited	Security practices	RQ3
FAST_MOVING_FIELD	Difficulty keeping up with rapidly changing cybersecurity recommendations	Compliance challenges	RQ2
AUTH_WEAK	Authentication mechanism that relies on identification (e.g., RFID UID, Modbus ID) rather than cryptographic authentication; borderline against Annex I Part I point 2(d).	Authentication mechanism quality	RQ1
ROLE_COVERAGE_GAP	Cybersecurity-relevant work concentrated in a single person, with no peer reviewer or distributed ownership.	Human and organisational preconditions	RQ3
LEADERSHIP_LATE	Leadership engagement in cybersecurity arrives only after a regulatory trigger or a named internal driver is in place, rather than from product-design intent.	Leadership engagement timing	RQ3
WRITE_DOWN_GAP	Cybersecurity decisions made outside formal artefacts are not recorded; day-to-day decisions leave no trace.	Documentation discipline	RQ3
MATURITY_DEVELOPING	Self- or analytically-positioned on the framework's Developing maturity track: some practice in place, room to formalise.	Maturity self-assessment	RQ1

REGULATORY_FORCING	Cybersecurity practice driven by regulatory forcing function (RED-DA / EN 18031 / CRA) rather than by design intent.	Regulatory drivers of practice	RQ2
SBOM_DONE	Software bill of materials generated and maintained, satisfying Annex I Part II point 1.	Supply-chain documentation	RQ2
UPDATE_MECH	Security-update delivery mechanism designed in (e.g., over-the-air via Wi-Fi STA), satisfying Annex I Part I point 2(c).	Update mechanism design	RQ1
CODE_REVIEW	Code review or security scan performed during firmware implementation, supporting Annex I Part I point 2(a) and Part II point 3.	Implementation hygiene	RQ1
BUILD_HYGIENE	Development and production environments separated; debug interfaces disabled or protected in production builds.	Implementation hygiene	RQ1
DATA_MIN	Personal-data and operational-data scope explicitly bounded at architecture time, satisfying Annex I Part I point 2(g).	Data minimisation	RQ1
POST_RELEASE_GAP	No written monitoring or patching plan, or no operational readiness for the CRA 24h/72h/14d reporting cadence, at the point the product enters pilot or release.	Post-release readiness	RQ2
TECH_DOC_DONE	Technical documentation file prepared (Annex VII style) covering general description, design, risk assessment, support period, standards used, tests, and declaration.	Documentation discipline	RQ2
RISK_SIGNOFF	Residual cybersecurity risks documented and formally accepted by management sign-off.	Management ownership of cybersecurity	RQ3
SUPPORT_COMMIT	Minimum five-year support period committed and communicated at the point of purchase, satisfying Art. 13(8) and Annex II point 7.	Lifecycle commitment	RQ2

B2 Observation Log (Pedaly Project)

25 decision-moment entries across the four PDLC phases and five cross-cutting themes from the JEMAC primary-case observation, September 2025 to April 2026. Source: Observation_Log.xlsx, sheet "1. Decision Moments". Columns are condensed for the appendix.

Moment ID	Phase	Decision (brief)	Decision Taken / Deferred	Written Record (Y/N)	Source Label
DM-P1-001	1	Decision 1.1 — CRA classification not made	Not made	N	[JEMAC-Documentary, pre-2025-09]
DM-P1-002	1	Decision 1.2 — Data scope mapping not made	Not made	N	[JEMAC-Documentary, pre-2025-09]
DM-P1-003	1	Decision 1.3 — Security requirements not written into product specification	Not made	N	[JEMAC-Documentary, pre-2025-09]
DM-P1-004	1	Decision 1.4 — Hardware platform security not evaluated (microcontroller (MCU) encryption gap)	Not made — MCU selected without security criteria	N	[JEMAC-Documentary, pre-2025-09]
DM-P1-005	1	Decision 1.5 — SDK / firmware platform security not evaluated	Ambiguous — to clarify	?	[JEMAC-Documentary, pre-2025-09]
DM-P1-006	1	Decision 1.6 — Supplier security confirmation ambiguous	Ambiguous — to clarify	?	[JEMAC-Documentary, pre-2025-09]
DM-P2-001	2	Decision 2.1 — Threat assessment retrofitted post-testing	Done, retrofitted post-design	Y	[JEMAC-Observation, 2025-10/2026-Q1]
DM-P2-002	2	Decision 2.2 — Authentication chosen: RFID UID + Modbus ID	RFID UID for users; Modbus ID for master-slave	Y	[JEMAC-Observation, 2025-10]
DM-P2-003	2	Decision 2.3 — Encryption substituted by physical controls (retrofit)	Physical controls (compensating); implemented later	Y	[JEMAC-Observation, 2025-11/2026-Q1]
DM-P2-004	2	Decision 2.4 — Security updates via STA (Wi-Fi Station mode)	over-the-air (OTA) updates via STA mode on the master node	Y	[JEMAC-Observation, 2025-10]

DM-P2-005	2	Decision 2.5 — Access control via RFID UID	RFID UID (identity-based, no roles)	Y	[JEMAC-Observation, 2025-10]
DM-P2-006	2	Decision 2.6 — Logging retrofitted	Implemented; retrofitted post-design	Y	[JEMAC-Observation, 2025-11/2026-Q1]
DM-P2-007	2	Decision 2.7 — Data minimisation considered	Data minimisation applied	Y	[JEMAC-Observation, 2025-10]
DM-P3-001	3	Decision 3.1 — Third-party library vulnerability check performed	Done	Y	[JEMAC-Observation, 2025-11]
DM-P3-002	3	Decision 3.2 — SBOM NOT generated (correction)	Not made	N	[JEMAC-Observation, 2025-12]
DM-P3-003	3	Decision 3.3 — Code review NOT performed (single FW engineer, no peer)	Not made — role coverage gap	N	[JEMAC-Observation, 2025-11]
DM-P3-004	3	Decision 3.4 — Dev / prod environment separation in place	Done	Y	[JEMAC-Observation, 2025-11]
DM-P3-005	3	Decision 3.5 — Secure by default (emergent, not deliberate)	Done — emergent from RED-DA compliance work, not designed in	Y	[JEMAC-Observation, 2025-12]
DM-P4-001	4	Decision 4.1 — No threat-based testing performed	Not made	N	[JEMAC-Observation, 2026-Q1]
DM-P4-002	4	Decision 4.2 — No formal essential-requirements verification	Not made (in CRA terms); RED-DA / EN 18031 evaluation done instead	Partial	[JEMAC-Observation, 2026-Q1]
DM-P4-003	4	Decision 4.3 — Technical documentation prepared	Done	Y	[JEMAC-Observation, 2025-11]
DM-P4-004	4	Decision 4.4 — Residual risk documented and accepted	Done	Y	[JEMAC-Observation, 2026-Q1]

DM-P4-005	4	Decision 4.5 — No monitoring and patching plan	Not made	N	[JEMAC-Observation, 2026-Q1]
DM-P4-006	4	Decision 4.6 — Not ready for 24-hour incident reporting	Not made	N	[JEMAC-Observation, 2026-Q1]
DM-P4-007	4	Decision 4.7 — Five-year support commitment in place	Done	Y	[JEMAC-Observation, 2025-11]
DM-T-001	—	Theme — Leadership engagement post-regulatory trigger only	Theme pattern across the project	Partial	[JEMAC-Observation, 2025-09/2026-04]
DM-T-002	—	Theme — Single named cybersecurity owner; concentrated role coverage	Theme pattern across the project	—	[JEMAC-Observation, 2025-09/2026-04]
DM-T-003	—	Theme — Cybersecurity work was both scheduled and squeezed in	Theme pattern across the project	—	[JEMAC-Observation, 2025-09/2026-04]
DM-T-004	—	Theme — Cybersecurity decisions outside formal artefacts not written down	Theme pattern across the project	—	[JEMAC-Observation, 2025-09/2026-04]
DM-T-005	—	Theme — JEMAC self-positions on the 'Developing' maturity track	Theme pattern across the project	—	[JEMAC-Observation, 2025-09/2026-04]

B3 Evaluation Ratings

Practitioner ratings from 1 (strongly disagree) to 10 (strongly agree). Blank cells were left unanswered. Source: Evaluation_Response_Tally.xlsx.

Participant codes: P1 to P5 are five JEMAC practitioners spanning management and engineering roles. To protect anonymity, quotes are attributed by participant code and by broad role, management or engineering, rather than by job title.

Item	Statement	P1	P2	P3	P4	P5	Mean
Background							
BK1	Familiar with CRA beforehand	8	7	5	6	4	6
BK2	Decisions consistent before framework	5	4	4	5	3	4.2
Clarity							
CL1	Diagram shows what/when	8	7	8	9	7	7.8
CL2	Phases & sequence clear	9	8	8	9	7	8.2
CL3	Checklist easy to understand	7	6	7	8	6	6.8
CL4	Each question unambiguous	7	5		7	6	6.2
CL5	Maturity-track columns clear	8	7	6	7	6	6.8
CL6	Adoption Readiness clear	9	8	9	8	7	8.2
CL7	CRA at a Glance clear	8	7	9	7	6	7.4
CL8	Post-release obligations clear	8	8	8	8	6	7.6

Utility							
UT1	Covers decisions that matter	8	7	8	9	6	7.6
UT2	Improves consistency	9	9	8	10	7	8.6
UT3	Improves traceability	9	8	9	10	7	8.6
UT4	Helps show customer/audit or	9	8	10	9	7	8.6
UT5	Improvement on current way	8	8	8	8	7	7.8
UT6	Overall useful	8	8	8	9	7	8
Utility by phase							
PH 1	Concept & Requirements useful	8	7	8	8	7	7.6
PH 2	Architecture & Design useful	9	9	7	8	8	8.2
PH 3	Implementation useful	7	9		8	5	7.2
PH 4	Validation & Release useful	8	7	7	9	6	7.4
Relevance							
RL1	Fits how team works	8	8	8	8	5	7.4
RL2	Track depth right	8	7	7	7	6	7
RL3	Scope right	7	6	8	8	6	7
RL4	Language/level suit	8	9	9	8	7	8.2
RL5	CRA focus relevant	9	7	9	7	7	7.8

RL6	Relevant to regulatory situation	8	7	9	7	6	7.4
Supporting artefacts							
SA1	Quick Start	8	8	8	9	7	8
SA2	Phase Decision Record	9	9	6	10	7	8.2
SA3	CRA Technical File Skeleton	9	7	7	8	6	7.4
SA4	Conformity Assessment Walkthrough	8	6	8	8		7.5
SA5	Incident Reporting Workflow	8	8	8	9	6	7.8
Adoption							
AD 1	Would adopt	7	7	7	7	6	6.8
AD 2	Format suits us	8	8	8	9	7	8
AD 3	Time acceptable	6	7	6	6	6	6.2
AD 4	Have skills	7	7	5	7	5	6.2
AD 5	Leadership support	8	6	9	8	7	7.6
Overall							
OV 1	Useful tool overall	8	8	8	8	7	7.8
OV 2	Would recommend	8	7	9	8	6	7.6
—	Maturity self-placement	Established	Developing	Developing	Developing	Starting	—
—	Per-respondent	8.0	7.4	7.9	8.1	6.4	7.6

	mean (excl. background)						

B4 Evaluation Written Comments

Free-text answers, reproduced verbatim and attributed by participant code.

Clarity — confusing or poorly worded?

P1: The diagram and phase model are clear at a strategic level. The one weak point is the maturity tracks: the boundary between Developing and Established is fuzzy, so a team could plausibly place itself in either. A one-line definition of each track up front would fix it.

P2: A few of the twenty-five Checklist questions bundle two asks into one, so a single rating cannot answer them honestly. The clearest example is the question that mixes secure storage of secrets with key rotation, which are separate decisions with separate owners. Splitting compound questions would sharpen the whole Checklist.

P3: As a non-engineer I found the diagram and the CRA at a Glance card genuinely readable, which is rare for security material. The detailed Checklist questions are clearly written for the technical team rather than for me, and that is fine, but the connection between the strategic overview and the detailed questions could be signposted more clearly.

P4: The phase sequence maps almost one-to-one onto our stage gates, which made it easy to follow. The only confusing part was overlap between the Adoption Readiness Checklist and the Relevance section; they ask similar things in different words, and I was not always sure which one to treat as authoritative.

P5: The framework is understandable, but the language leans heavily toward software. Terms like secure update, SBOM, and vulnerability handling are framed as code concerns, and as an engineer I had to translate them to my world (secure boot, debug-port lockdown, tamper protection, component sourcing). A hardware-oriented gloss would help.

Utility — what is missing?

P1: Nothing major is missing for governance. What is thin is the link to supplier and component management. As an established SME we inherit most risk through third-party software and silicon, and the framework treats the product as if we build it all ourselves. A decision point on third-party/SBOM risk would close that gap.

P2: What is missing is the operational/runtime side: logging, telemetry, and how a vulnerability gets triaged once the product is in the field. The framework is strong on design-time decisions but goes quiet on the feedback loop from production back into the next release.

P3: From a business view nothing is missing on the risk side. What is missing is cost and effort: I cannot tell from the framework what adopting it will cost in people and time, and that is the number I have to weigh against everything else competing for the same team.

P4: What is missing is integration with how we already track work. The decisions need owners, due dates, and a status, otherwise they live in a document nobody reopens. As a planning artefact it needs to express who, by when, and done/not-done, not just whether a decision is good.

P5: The hardware and supply-chain dimension is largely missing. There are no clear decision points for debug/JTAG interface lockdown, secure element selection, key provisioning on the line, or counterfeit-component risk. For a device where the radio and silicon are the product, that is a real gap.

Phases — most and least useful

P1: Architecture and Design is the most useful phase for us because that is where security debt is locked in and where the cost of getting it wrong is highest. Implementation is the least useful as written, since our engineers already have secure-coding standards and the decision points there restate what our pipeline enforces.

P2: Implementation and Architecture are the most useful to me because that is where I make concrete trade-offs (crypto choices, update mechanism, attack surface). Concept and Requirements is the least useful from an engineering seat; it is important, but the decisions there are usually settled before I am in the room.

P3: I am best placed to judge Concept and Requirements, and that is the most useful phase for me because it forces the security and market-access conversation early, while choices are still cheap. I cannot meaningfully judge Implementation and have left it blank.

P4: Validation and Release is the most useful phase for me because it produces the evidence I have to show at the final gate, and traceability is exactly what I am measured on. Concept is useful too but harder to schedule. None of the phases felt unhelpful.

P5: Architecture and Design is the most useful because that is where hardware security choices (secure element, boot chain, interface exposure) are actually fixed. Implementation is the least useful to me as written, because it reads as a software-build phase and barely acknowledges board bring-up or provisioning.

Relevance — which regulation matters most

P1: The CRA matters most. We sell products with digital elements into the EU, so CRA conformity is now a gating requirement for market access, and it pulls RED security articles along with it. NIS2 touches us as an operator but is secondary to the product obligations.

P2: CRA in practice, because its secure-update and vulnerability-handling expectations land directly on the code I own. GDPR matters for the cloud API where we touch personal data, but the CRA technical obligations are the ones that change how I build.

P3: The CRA, without question. It is becoming a condition of selling into our largest market, so for me it is a commercial gate, not just a compliance topic. That is the regulation that turns this from a nice-to-have into something I will fund.

P4: CRA drives our planning because its conformity and reporting obligations create hard deliverables and deadlines I have to build into the schedule. Given our device type GDPR is also live, but CRA is what reshapes the project plan.

P5: RED is the most relevant to us because we ship radio modules and the RED cybersecurity articles govern market access for our hardware. CRA matters and is coming, but day to day it is RED and its harmonised standards that gate what we can sell.

Supporting artefacts — add or remove

P1: The CRA Technical File Skeleton is the highest-value artefact and worth expanding. I would add a short supplier/SBOM declaration template, as that is the artefact we are repeatedly asked for and currently assemble ad hoc.

P2: The Phase Decision Record template is the most useful because it gives a place to record the why behind a decision, which is exactly what we lose today. The Conformity Assessment Walkthrough felt aimed at a compliance lead rather than an engineer, so I would not reach for it.

P3: The Quick Start guide and the CRA at a Glance card are the artefacts I would actually use to brief the board and customers. The deeply technical skeletons are for the team; I did not review the Conformity Assessment Walkthrough in detail.

P4: The Phase Decision Record template is outstanding for my role, it is basically a ready-made gate artefact. The Incident Reporting Workflow is valuable but sits more with operations than with me during development; I would keep it but flag its owner clearly.

P5: The Quick Start guide and Phase Decision Record are useful and format-neutral. I did not review the Conformity Assessment Walkthrough in depth and left it blank. What I would add is a hardware/provisioning checklist, that is the supporting document I am actually missing.

Adoption — biggest barrier and one change

P1: The biggest barrier is engineering time during delivery crunch, not willingness. The single change that would most improve usability is a tiered minimum set: an explicit short-

list of the must-do decisions per phase, so a team under pressure knows what cannot be skipped.

P2: The biggest barrier is that it competes with delivery deadlines and has no tooling hook. If the Phase Decision Record existed as a template in our repo / issue tracker rather than a separate document, it would get filled in as part of normal work instead of being an afterthought.

P3: The biggest barrier is competing priorities and the unknown cost. The one change that would most help me say yes is a simple effort estimate, roughly how many person-days per phase for a team our size, so I can plan it against delivery commitments.

P4: The biggest barrier is that it is a standalone document rather than something wired into our project tooling, so it risks being filled in once and forgotten. The single change I would make is to add owner / due-date / status fields to each decision so it behaves like a tracked deliverable.

P5: The biggest barrier for us is skills and the software framing; as a small team starting out we do not have a dedicated security person, and the framework assumes more software-security fluency than we have. The one change that would most help is concrete hardware examples and a Starting-track that does not presume a software pipeline.

Overall — final comments

P1: A genuinely useful piece of work. With tighter maturity-track definitions and a supplier-risk decision point it would map almost completely onto how we run product development.

P2: Solid and clearly written. Split the compound checklist items and add a runtime/vulnerability- handling thread and it would fit an engineering team very well.

P3: This is the first cybersecurity material I have been handed that I could read end to end and act on. Leadership support will not be the barrier; give me the cost picture and we will back it.

P4: Very well structured for stage-gated delivery. Add tracking fields and clarify the Adoption vs Relevance overlap and it would slot straight into our process.

P5: A good foundation, but it currently reads as a software framework. Add hardware and supply- chain decision points and plainer examples for a Starting-level team and it would be far more relevant to engineers like me.

Appendix C — Framework Artefacts

C1 Framework Diagrams

Overview, hero (four phases and twenty-five decisions), and maturity-calibration diagrams from the framework artefact bundle.

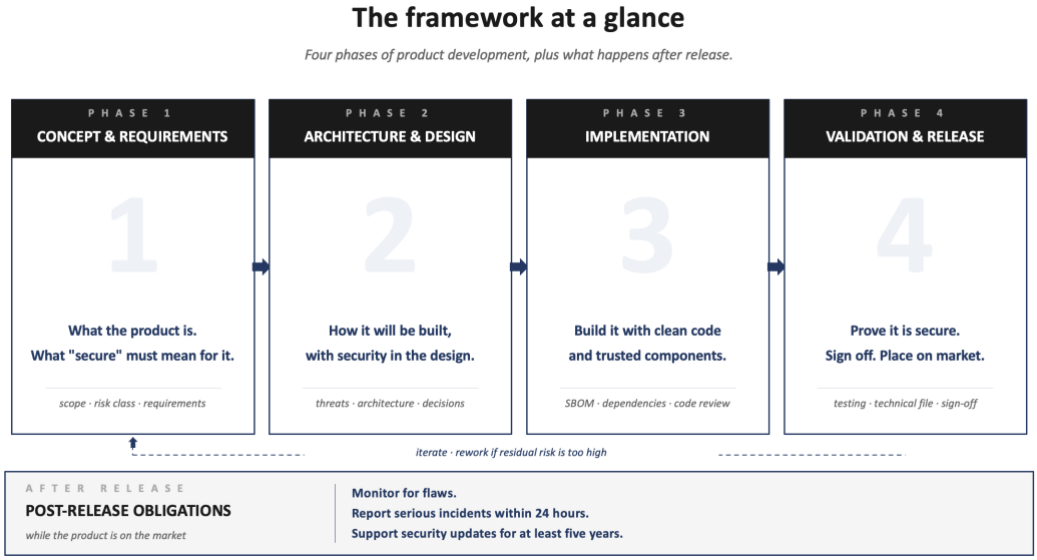


Figure C1.1 Overview

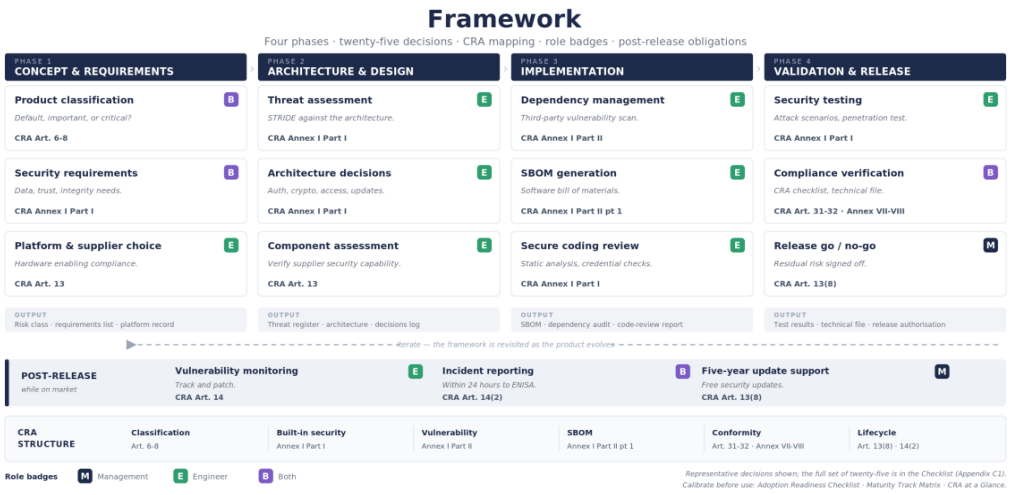


Figure C1.2 Phases and decisions (hero)

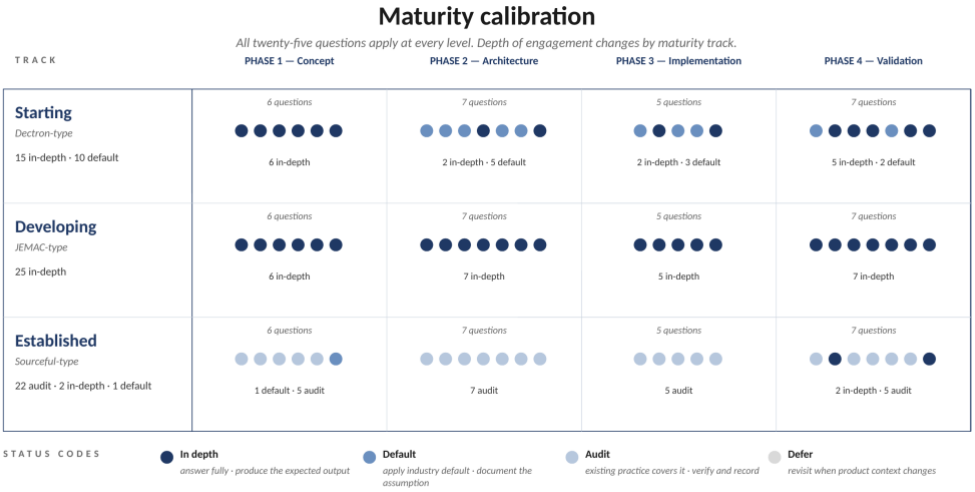


Figure C1.3 Maturity calibration

C2 Adoption Readiness Checklist

Adoption Readiness Checklist

Conditions for use of the framework. Walk through these as a team before you open the framework on a real product.

HOW TO USE THIS

A precondition check, not a scoring tool. Take fifteen to thirty minutes. Be honest about **No** answers, because each **No** marks a gap that the framework will not close for you on its own.

Governance

Who decides, who owns it, and what room they have to act.

#	QUESTION	YES	NO
1	**A senior leader (CEO, founder, or equivalent) has committed to running this framework on at least one product.** *Why we ask. Leadership commitment was the trigger that moved JEMAC into active adoption. The absence of a senior trigger is what keeps Dectron at the threshold.*	☐	☐
2	**One named person is responsible for shepherding the framework day to day.** *Why we ask. Cybersecurity work disperses across people unless someone owns it. JEMAC hired a quality engineer for this reason.*	☐	☐
3	**That owner has a realistic block of time set aside for this work in the next product cycle.** *Why we ask. Time is the dominant competing priority for SME engineering teams. The owner needs scheduled time, not leftover time.*	☐	☐
4	**The team has access to external expertise (consultants, test houses, legal advice) when an internal answer is not enough.** *Why we ask. JEMAC used external consultants to interpret the RED Directive. Some questions will exceed what a small team can answer alone.*	☐	☐
5	**Senior leadership has agreed that the release date can move if residual security risk is too high.** *Why we ask. Several participants said they would ship and patch later if a customer deadline demanded it. The framework cannot do its job if the go/no-go is foreclosed before Phase 4.*	☐	☐

Human factors

Whether the team can interpret, integrate, and sustain the work.

#	QUESTION	YES	NO
6	**At least one person on the team is comfortable reading regulatory text and translating it into product requirements.** *Why we ask. Five of the eight interview participants named interpretation of standards and regulations as the single hardest part of compliance.*	☐	☐
7	**At least one manager and at least one engineer are committed to using the framework together.** *Why we ask. Management wants checklists and go/no-go signals. Engineers want technical depth. The framework only works if both roles engage with it.*	☐	☐
8	**The team can name where the framework will plug into the existing process: stage gates, sprint reviews, design reviews, or equivalent.** *Why we ask. Participants were clear that they would not adopt a separate parallel system. The framework needs an anchor in how the team already works.*	☐	☐
9	**The framework outputs (decisions, records, evidence) can be filed into the team's existing quality management system or record-keeping practice.** *Why we ask. JEMAC integrates cybersecurity work into its quality processes. Without a place to file the records, they will not be there when the CRA technical file is required.*	☐	☐
10	**The team is willing to write decisions down in a form that survives if a key person leaves.** *Why we ask. All three companies relied heavily on individual experience for cybersecurity decisions. Writing it down is the framework's antidote.*	☐	☐
11	**The team has been honest about which maturity track describes them today: Starting, Developing, or Established.** *Why we ask. The framework calibrates differently for each track. Picking the wrong track makes the framework either pointlessly heavy or dangerously light.*	☐	☐
12	**The team is willing to act on cybersecurity now even if no customer is currently asking for it.** *Why we ask. At JEMAC and Dectron, customers are not yet asking about CRA. The regulation does not wait for customer demand.*	☐	☐
13	**There is an agreed plan for what happens when a security question collides with a customer deadline.** *Why we ask. Time pressure was the dominant competing priority across the cases. Decide in advance who escalates, who decides, and which kinds of risk are non-negotiable.*	☐	☐

Interventions

For every No, a concrete next step. Do these before opening the framework, not in parallel with it.

#	IF NO, DO THIS NEXT
1	Book a thirty-minute meeting with the senior leader. Walk through the Quick Start and the CRA timeline (enforcement from 2027). Frame the cost of inaction with the JEMAC precedent: late adoption forces architectural workarounds. Leave with a written commitment to run the framework on one product.
2	Name one person now. They do not need to be a security specialist. They need to be accountable for moving the framework through phases and filing the outputs. If no internal candidate, scope an external consultant for at least the first cycle.
3	Block calendar time. Estimate roughly one day per phase for a Starting team, more for Developing. If this conflicts with current priorities, escalate to leadership before the cycle starts, not during.
4	Identify and pre-vet at least one external resource: a cybersecurity consultant, a test house, and a legal advisor familiar with the CRA. Even if not engaged yet, knowing who to call cuts response time.
5	Get a written statement from leadership: a release can move if residual security risk is unacceptable. Define what unacceptable means in advance, even loosely (for example, any unmitigated critical Common Vulnerabilities and Exposures (CVE) entry in a connected component).
6	Identify the person who will read CRA text and translate it into product terms. If no one internally, this is the first external consultant. Without this capacity, the framework stalls in Phase 1.
7	Run a thirty-minute joint kickoff with the manager and lead engineer. Walk through the Hero diagram. Each names a phase or decision they personally own. Document the agreement.
8	Map the four framework phases onto your existing process: stage gates, sprint review cadence, design reviews, or release checkpoints. One sheet, four phases, where each lands. If your process has no natural gates, add four (one per phase).
9	Decide where outputs will live. If you have a formal quality management system (QMS), add a cybersecurity section. If you do not, set up a shared folder per phase with a naming convention. Wire it in before the first phase, not after.
10	Adopt the Phase Decision Record template. Commit to filling one per phase. Add the template to your project setup so it is there at kickoff, not bolted on later.
11	Run a ten-minute team conversation. Use the JEMAC, Dectron, and Sourceful profiles as anchors. Be honest about where you actually are, not where you would like to be. Picking the wrong track skews everything downstream.
12	Surface this as a leadership decision, not a team decision. The case is competitive: CRA-ready manufacturers gain advantage as customer awareness catches up. JEMAC moved from sceptic to "competitive advantage" framing within nine months.
13	Pre-decide. Write down: who escalates, who decides, which risks are non-negotiable (for example, an unmitigated critical CVE in a connected component cannot ship). Reference this when the first collision lands.

How to read the result

Use the count of **No** answers, not the count of **Yes**.

Zero No. You are ready to open the framework on a real product.

One or two No. Address those specific gaps first. The framework will hit those exact points and stall.

Three or more No. Step back. Running the framework now will produce records that do not stick.

C3 CRA at a Glance

CRA at a Glance

How the framework maps to the EU Cyber Resilience Act.

CRA OBLIGATION	ARTICLE	WHAT IT REQUIRES	IN THE FRAMEWORK
Product classification *Classification*	**Art. 6-8**	Decide whether the product is default, important (class I or II), or critical. The class determines whether self-assessment is enough, or third-party certification is required.	*Phase 1 · Decision 1.1*
Built-in security *Built-in security*	**Annex I, Part I**	Ten properties the product must have: secure by default, protection from unauthorised access, confidentiality, integrity, processing only necessary data, availability, limited attack surface, reduced incident impact, security event logging, and a secure update mechanism.	*Phase 1 · 1.3 · Phase 2 · 2.2 · Phase 3 · 3.3 · Phase 4 · 4.1*
Vulnerability handling *Vulnerability*	**Annex I, Part II**	Identify and document vulnerabilities, fix them without delay, share information about fixes, distribute security updates, and operate a coordinated vulnerability disclosure policy.	*Phase 3 · 3.1 · Post-release*
Manufacturer reporting *Vulnerability*	**Art. 14**	Notify ENISA of actively exploited vulnerabilities and of severe incidents that affect product security, and inform users of corrective measures.	*Post-release · vulnerability monitoring*
24-hour incident reporting *Lifecycle*	**Art. 14(2)**	An early-warning notification must reach ENISA and the relevant national CSIRT within twenty-four hours of becoming aware of an actively exploited vulnerability or a severe incident.	*Post-release · incident reporting*
Software bill of materials *SBOM*	Annex I Part II point 1	Maintain a machine-readable SBOM covering at least the top-level dependencies of the product, and keep it up to date through the support period.	*Phase 3 · 3.2*
Manufacturer due diligence *Conformity & docs*	**Art. 13**	When integrating third-party components, the manufacturer must take reasonable steps to ensure those components do not compromise the cybersecurity of the product. Applies to both hardware and software suppliers.	*Phase 1 · 1.4-1.6 · Phase 2 · 2.3 · Phase 4 · 4.3*
Conformity assessment *Conformity & docs*	Art. 31; Art. 32; Annex VII; Annex VIII	Demonstrate compliance through internal control (Annex VIII for most products) or third-party assessment (for important and critical classes). A technical file must be prepared and kept up to date.	*Phase 4 · 4.2*

CRA OBLIGATION	ARTICLE	WHAT IT REQUIRES	IN THE FRAMEWORK
Five-year minimum support *Lifecycle*	Art. 13(8); Annex II point 7	Provide free security updates for the expected product lifetime, with a minimum of five years from the date of placing on the market.	*Phase 4 · 4.3 · Post-release*

How to use this card

Read this card alongside the framework diagram. Each row identifies one CRA obligation, what it actually requires in plain words, and which decision points in the framework address it. If you are unsure how a checklist question maps to the regulation, this card is the bridge.

What is not covered here

This card focuses on obligations that shape product development. It does not cover market surveillance procedures, penalties, importer or distributor obligations, or open-source software exemptions. For those, refer to the full text of Regulation (EU) 2024/2847.

C4 Checklist (25 Questions in Phase Order)

Checklist

The twenty-five decision questions of the framework, in phase order. Use this as the working tool while building a product.

HOW TO USE THIS

Walk through each phase in order. For every question, decide what good looks like for your product and record the answer. The three track columns to the right of QUESTION (Starting, Developing, Established) tell you how deep to go on each, given your maturity track. The CRA tag on each question is the regulatory clause the question discharges. The role badge tells you who owns the answer: M (management), E (engineer), or B (both).

Phase 1 — Concept and requirements

#	QUESTION	CRA	ROLE	DONE
1.1	**What is the product's CRA classification? Default, important class I or II, or critical?** *What good looks like. A documented class decision with reasoning, citing Art. 6-8 and the Annex III list for important and critical classes.*	Art. 6-8	B	☐
1.2	**What data does the product collect, process, store, or transmit?** *What good looks like. A short data-flow note listing what the product collects, where it travels, and where it rests.*	Annex I, Part I	B	☐
1.3	**What are the security requirements for this product?** *What good looks like. A requirements list that names the security properties the product must meet: confidentiality, integrity, availability, authenticity.*	Annex I, Part I	B	☐
1.4	**Does the chosen hardware platform support the required security capabilities?** *What good looks like. A platform datasheet or vendor statement covering crypto acceleration, secure boot, and secure storage. Reject platforms that cannot meet the requirements set in 1.3.*	Art. 13	E	☐
1.5	**Can the chosen software platform or SDK deliver the required security?** *What good looks like. Confirmation from the SDK vendor that the security features in 1.3 are supported, with versions pinned.*	Art. 13	E	☐
1.6	**Has the supplier confirmed support for the security features?** *What good looks like. Written supplier confirmation. A signed CoC or a statement on vendor letterhead is sufficient at Starting; a contract clause is the target at Developing and above.*	Art. 13	E	☐

Phase 2 — Architecture and design

#	QUESTION	CRA	ROLE	DONE
2.1	**What threats has the product been assessed against, for example using STRIDE?** *What good looks like. A threat model. STRIDE applied per data-flow boundary. Lightweight at Starting, full register at Developing, routine at Established.*	Annex I, Part I	E	☐
2.2	**How will users authenticate to the product?** *What good looks like. A documented auth design: who authenticates, how (multi-factor authentication (MFA), certificate, shared key), and what backstops a lost credential.*	Annex I, Part I	E	☐
2.3	**What data is encrypted in transit and at rest? What encryption is used?** *What good looks like. A list of every data category, where it sits and travels, the algorithm and key length, where keys live, and how they rotate.*	Annex I, Part I	E	☐
2.4	**How will the product receive security updates? Can updates be authenticated and applied securely?** *What good looks like. A signed-update path: the device verifies updates against a publisher key it trusts, applies them atomically, and can roll back on failure.*	Annex I Part I point 2(c); Art. 13(9); Annex I Part II point 7	E	☐
2.5	**What access control model is used? Are permissions limited to least privilege?** *What good looks like. An access control matrix. Each role lists what it can read, write, and execute. Default deny.*	Annex I, Part I	E	☐
2.6	**Does the product log security-relevant events? Can these logs be reviewed?** *What good looks like. A list of logged events (auth, privilege change, config change, update applied) and a documented process for reviewing them.*	Annex I, Part I	E	☐
2.7	**What personal data does the product handle, and how is data minimised?** *What good looks like. A data inventory mapping each personal data element to a lawful basis, retention period, and minimisation step.*	Annex I, Part I	E	☐

Phase 3 — Implementation

#	QUESTION	CRA	ROLE	DONE
3.1	**Have all third-party libraries been checked for known vulnerabilities?** *What good looks like. A dependency manifest with current vulnerability status. No critical CVEs are left unaddressed. Vendor or scanner attestation on file.*	Annex I, Part II	E	☐
3.2	**Has a software bill of materials (SBOM) been generated?** *What good looks like. A machine-readable SBOM in CycloneDX or SPDX format covering at least the top-level dependencies. Regenerated per build.*	Annex I Part II point 1; Art. 3(39); Art. 13(24)	E	☐
3.3	**Has the code been reviewed or scanned for common security flaws?** *What good looks like. A static analysis report against language and framework-appropriate rules. Findings are triaged and recorded.*	Annex I, Part I	E	☐
3.4	**Are development environments isolated from production?** *What good looks like. Separation between dev, staging, and production. Credentials do not cross. No production data in dev.*	Annex I Part I points 2(d), 2(j), 2(k)	E	☐
3.5	**Is the product configured to be secure by default?** *What good looks like. Out-of-the-box configuration is secure. Default passwords force a change on first use. Optional services are off by default.*	Annex I Part I point 2(b)	E	☐

Phase 4 — Validation and release

#	QUESTION	CRA	ROLE	DONE
4.1	**Has the product been tested against the threats identified?** *What good looks like. Test plan and results covering each threat from 2.1. Penetration test for important and critical classes.*	Annex I, Part I	E	☐
4.2	**Have all essential CRA requirements applicable to this product class been verified?** *What good looks like. A mapped checklist showing each essential requirement (Annex I, Part I and Part II) and the artefact that satisfies it.*	Art. 32; Annex VII; Annex VIII	B	☐
4.3	**Has the required technical documentation been prepared (Annex VII)?** *What good looks like. A technical file conforming to the Annex VII structure. Kept current as the product changes.*	Art. 31; Annex VII	B	☐
4.4	**Are residual security risks documented, understood, and accepted?** *What good looks like. A risk register showing residual risks, owners, mitigations, and a leadership sign-off entry with a date.*	Annex I, Part I	M	☐
4.5	**Is there a plan for monitoring and patching vulnerabilities post-release?** *What good looks like. A vulnerability monitoring plan: vendor advisory subscriptions, scan cadence, who triages, target response times.*	Annex I Part II points 2, 7-8	B	☐
4.6	**Is there a process for reporting actively exploited vulnerabilities within 24 hours?** *What good looks like. A documented incident decision tree and a 24-hour notification path to ENISA and the national CSIRT, with named contacts.*	Art. 14(2)	B	☐
4.7	**Is the product committed to receiving security updates for at least 5 years?** *What good looks like. A written support-period commitment (minimum five years) with budget assigned and an owner named.*	Art. 13(8); Annex II point 7	M	☐

Questions are drawn from the practical checklist of the framework. Three track columns (Starting, Developing, Established) carry per-track depth coding. Lives in /Framework Development/v3/.